



Federal Office  
for Information Security

# BSI Technical Guideline TR-03166

Technical Guideline for Biometric Authentication Systems

Version: 2.0



# Version History

*Tab. 1 Version history of the technical guideline.*

| <i><b>Version</b></i> | <i><b>Date</b></i> | <i><b>Editors</b></i> | <i><b>Description</b></i>                                                                                      |
|-----------------------|--------------------|-----------------------|----------------------------------------------------------------------------------------------------------------|
| 0.92                  | 2021               | BSI                   | First draft version for external revision                                                                      |
| CD 1.0                | 2021               | BSI                   | Added missing part Reference Creation.<br>Adjusted wording regarding to ISO/IEC 2382-37-2017                   |
| 1.1                   | 2024               | BSI                   | Changes regarding errors in header.<br>Added literature.<br>Changed requirements.<br>Changed title page.       |
| 2.0 Draft             | 2025               | BSI                   | Change of requirements<br>Restructuring of mandatory requirements and “optional requirements”                  |
| 2.0                   | 2026               | BSI                   | Solved inconsistencies<br>Reworked structure chapter 2<br>Reworked Annex<br>Renamed Biometric Assurance Levels |

# Table of Contents

|       |                                                                                                                   |    |
|-------|-------------------------------------------------------------------------------------------------------------------|----|
| 1     | Introduction.....                                                                                                 | 5  |
| 1.1   | Motivation.....                                                                                                   | 5  |
| 1.2   | Scope.....                                                                                                        | 5  |
| 1.2.1 | Extent of the Biometric Authentication Component Evaluation .....                                                 | 6  |
| 1.3   | Framework.....                                                                                                    | 7  |
| 1.4   | System Model .....                                                                                                | 7  |
| 1.5   | Overview .....                                                                                                    | 9  |
| 1.5.1 | How to use this Technical Guideline.....                                                                          | 9  |
| 1.5.2 | Target group.....                                                                                                 | 9  |
| 1.5.3 | Target of Evaluation (TOE).....                                                                                   | 9  |
| 1.6   | Key Words .....                                                                                                   | 10 |
| 1.7   | Key Documents.....                                                                                                | 10 |
| 1.7.1 | Authentication Methods According to Existing Standards and Documents .....                                        | 10 |
| 2     | Biometric Verification as an Authentication Factor (Informative).....                                             | 15 |
| 2.1   | Authentication Factors.....                                                                                       | 15 |
| 2.1.1 | Biometric Verification for Authentication .....                                                                   | 15 |
| 2.2   | Exemplary Biometric Authentication / Verification System with its Subsystems.....                                 | 19 |
| 2.2.1 | Biometric Sample Capture Subsystem .....                                                                          | 20 |
| 2.2.2 | Signal Processing Subsystem .....                                                                                 | 20 |
| 2.2.3 | Reference Creation.....                                                                                           | 22 |
| 2.2.4 | Biometric Enrolment Database.....                                                                                 | 22 |
| 2.2.5 | Comparison Subsystem.....                                                                                         | 23 |
| 2.2.6 | Decision Subsystem.....                                                                                           | 23 |
| 2.2.7 | Communication of the Biometric Verification / Authentication Result .....                                         | 24 |
| 2.3   | Attack Vectors on a Biometric System.....                                                                         | 24 |
| 2.3.1 | Attack Against the Biometric "Sample Acquisition" .....                                                           | 24 |
| 2.3.2 | Information Transmission Attack .....                                                                             | 25 |
| 2.3.3 | Signal Processing Subsystem Attack .....                                                                          | 26 |
| 2.3.4 | Biometric Enrolment Database Attack.....                                                                          | 26 |
| 2.3.5 | Comparison Subsystem Attack .....                                                                                 | 26 |
| 2.3.6 | Comparison Decision Subsystem Attack .....                                                                        | 27 |
| 2.4   | Recommendation and Considerations when Using Biometric Modalities for Authentication / Verification Process ..... | 27 |
| 2.4.1 | Modality Finger .....                                                                                             | 27 |
| 2.4.2 | Modality Face .....                                                                                               | 28 |
| 3     | Requirements on Biometric Authentication / Verifications Systems (Normative) .....                                | 30 |

---

|       |                                                                                  |    |
|-------|----------------------------------------------------------------------------------|----|
| 3.1   | [GEN] General Requirements .....                                                 | 30 |
| 3.2   | [BAL-1] Requirements for Biometric Assurance Level 1 .....                       | 32 |
| 3.2.1 | [BAL-1] Biometric Performance and Presentation Attack Detection.....             | 32 |
| 3.2.2 | [BAL-1] Multibiometrics (Conditional) .....                                      | 32 |
| 3.2.3 | Enhancing BAL 1 to BAL 2 .....                                                   | 33 |
| 3.3   | [BAL-2] Requirements for Biometric Assurance Level 2 .....                       | 34 |
| 3.3.1 | [BAL-2] Biometric Performance and Presentation Attack Detection.....             | 34 |
| 3.3.2 | [BAL-2] Multibiometrics (Conditional) .....                                      | 34 |
| 3.3.3 | Enhancing BAL 2 to BAL 3 .....                                                   | 35 |
| 3.4   | [BAL-3] Requirements for Biometric Assurance Level 3 .....                       | 36 |
| 3.4.1 | [BAL-3] Biometric Performance and Presentation Attack Detection.....             | 36 |
| 3.4.2 | [BAL-3] Multibiometrics (Conditional) .....                                      | 36 |
| 3.4.3 | [BAL-3] Multimodality (Conditional) .....                                        | 36 |
| 4     | Capture of Biometric Characteristics and Enrolment Processes (Informative) ..... | 38 |
| 4.1   | Modality Finger .....                                                            | 38 |
| 4.2   | Enrolment Quality Recommendation .....                                           | 38 |
| 4.3   | Re-enrolment and Suspension of a Biometric Characteristic .....                  | 39 |
| A1.   | Terms and Definitions .....                                                      | 40 |
| A2.   | Improving Biometrics Usability.....                                              | 43 |
| A3.   | General Concepts for Improving Biometric Security .....                          | 44 |
| A4.   | Abbreviation List .....                                                          | 46 |
| 5     | Bibliography .....                                                               | 47 |

# 1 Introduction

## 1.1 Motivation

In the last decade, the development of computing devices has been focused on accessibility, usability and versatility; modern smartphones are the best example for this trend. Due to the availability of new technologies and a continuously growing variety of online services, our behaviour and daily life have changed significantly. In the context of digitalisation, more and more services are offered over the internet. The increasing availability of internet access and the functionalities of current devices, especially mobile devices like smartphones, have transformed them into control centres for many applications. These manifold applications expose users to higher risks. Indeed, successful authentication on a single device is sufficient to access financial services, health applications, public authority services (eGovernment), communication and smart home functionalities.

Classic protection methods against unauthorized access are strong passwords or special hardware tokens, epitomizing the authentication factors knowledge and possession. As an alternative, biometric technologies like face or fingerprint recognition are steadily gaining attention as a more convenient and hence widely accepted authentication factor. Nowadays almost all devices like tablets, smartphones and laptops have some form of integrated biometric subsystem for enrolment and authentication on the device. Considering the increasing damage potential of current online services, it is vital to accurately assess the security level of the authentication technologies and processes, which are in use to protect the online services.

In contrast to the clear advantage of biometric technologies in terms of convenience and speed as compared to classic authentication methods, assessing their real-life security level is a highly challenging and still heavily debatable topic. Many current security standards and normative regulations consider only the robustness against a brute-force attack when evaluating the security level of an authentication method. Even for classic authentication methods like passwords, the focus on entropy neglects many practically relevant attack vectors, like easily guessable passwords, various snooping techniques, etc. For biometric methods, this simplified approach would definitely fall too short. Biometric performance always depends on several parameters like sensor properties, biometric comparison algorithms, environmental factors or the biometric features of the data subject. In addition, the overall security level of biometric methods in unsupervised settings is highly dependent on their resistance against various attacks based on artificial or augmented biometric characteristics.

## 1.2 Scope

The scope of this technical guideline is to define requirements for biometric authentication / verification systems including their subsystems in terms of the:

1. biometric performance
2. attack resistance against Presentation Attacks (PA)

Both parts, biometric performance and attack resistance, are critical for the security assessment of a biometric system and have to be evaluated properly. Due to several subsystems within the biometric authentication / verification process, this document focusses on Presentation Attacks at the Sensor level, as shown in Figure 1 for the modalities finger and face. Currently, all other possible attack vectors, like data handling and storage issues, are out of scope or can be covered by common IT security measures and methods.

Biometrics as an authentication factor is from its characteristics different compared to knowledge- and possession-based authentication factors. Due to its probabilistic character biometrics has to deal with uncertainties, like natural variations of a person or changes associated with the presentation process. Therefore, biometrics has to be handled differently compared to other authentication factors, e.g. introducing thresholds for the biometric comparison.

This technical guideline is mainly directed towards manufacturers and developers of devices and services and service provider implementing biometrics as an authentication / verification with the aim to achieve a certification for their biometric authentication / verification system (1:1 comparison). This technical guideline often uses the smartphone as a daily life example, but it does not mean that the technical guideline is only applicable to smartphones.

The main evaluation framework is based on the definition of BSI Biometric Assurance Levels (BALs), which are partially derived from eIDAS Regulations 910/2014 [1] and 2024/1183 [2] and BSI TR-03107 [3] and their requirements on authentication factors and interpreted for the peculiarities of biometrics. With this principle our technical guideline can be applied to more use cases and applications than defined by eIDAS and BSI TR-03107.

This technical guideline does not apply to identification processes (1:N comparison) and biometric authentication scenarios regulated by BSI TR-03121 [4] and the corresponding conformity specifications defined in BSI TR-03122 [5]. Such scenarios are for example border control, German identity Documents, alien register enrolment and immigration authorities.

Note: This technical guideline can be applied to all processes, even if it is name includes “identification”, as long as it is based on a 1:1 comparison as stated before.

### 1.2.1 Extent of the Biometric Authentication Component Evaluation

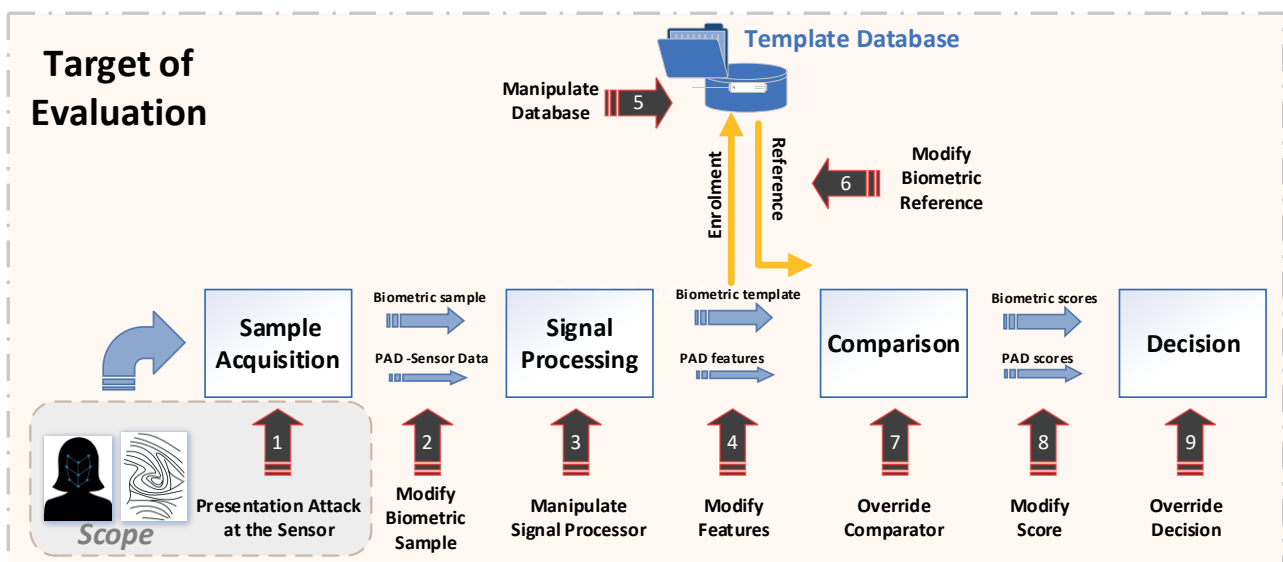


Figure 1 The Target of Evaluation of this technical guideline is highlighted by the yellow box and contains all subsystems, necessary for a functional biometric system. In addition, the grey dashed box covers the attack vector (Presentation Attack (PA) at the sensor), which is in scope of this technical guideline.

This technical guideline does not allow testing or certification of single components (e.g., a fingerprint sensor for the sample acquisition without further subsystems for comparison and decision, as shown in Figure 1). Instead, the product with its hard- and software necessary for the biometric authentication can be certified as a biometric verification subsystem for authentication.

Note: Before the evaluation and certification, the Target of Evaluation (TOE) and its necessary hard- and software components and their settings for a functional biometric authentication system will be defined. Components that are not fundamental and security-relevant for the functional biometric authentication system can be excluded in the evaluation and certification process.

Example: A computation unit is necessary to process the acquired data, but is not necessarily part of the TOE.

If possible, the hardware developers can provide different configurations to match different BALs. Application developers can call these configurations for the required BAL.

## 1.3 Framework

This technical guideline consists of two parts:

- Technical Guideline BSI TR-03166
- Evaluation Guidance (EG)

The first document defines the requirements of the biometric authentication / verification system. The second document is the EG, which defines the metrics and procedures regarding the evaluation of the biometric performance and the Presentation Attack Detection (PAD).

## 1.4 System Model

The most prominent examples for biometric authentication processes in daily life are mobile devices and in particular smartphones. These complex systems are able to run a huge variety of services and applications, which leads to many potential threats, if the security of such a device's authentication mechanism is compromised.

A correspondingly secure authentication mechanism in such systems is equipped with systems for both biometric decision including a Presentation Attack Detection (PAD) decision, with its subsystems (see Figure 1, for details subsection 2.2).

A bona fide user (see [6], [7]) can typically use authentication factors to gain access to, e.g.:

- specific locations (rooms, buildings)
- devices (smartphones, personal computers)
- services (login processes)

As a first step, a specific authentication factor has to be registered. For the registration of a biometric authentication factor, this step is called enrolment. Afterwards, this authentication factor can be used for authentication and verification purposes.

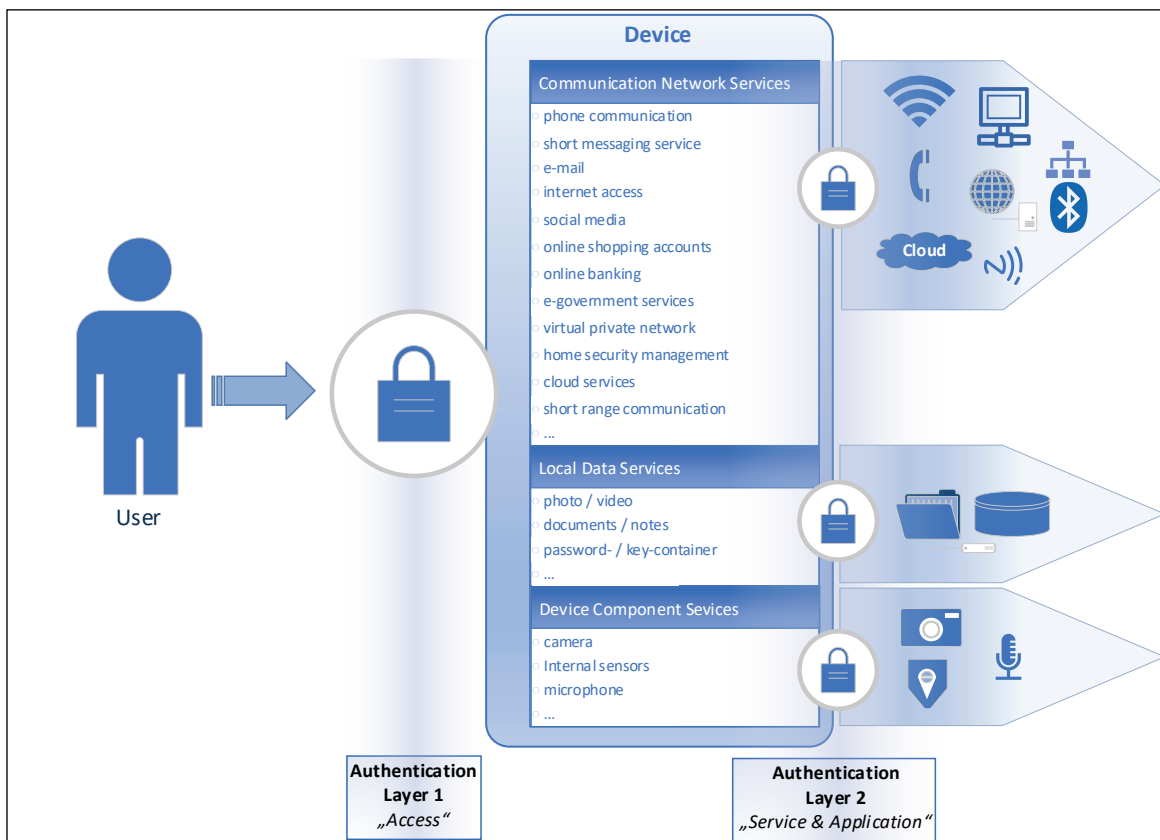
Figure 2 depicts a two-step authentication, which can be found, e.g., on smartphones. In the first step (access-level), the data subject unlocks the device by using an authentication factor, which can be a password / PIN (Personal Identification Number), a hardware token (possession-based factor) and biometrics.

Biometrics can be used to improve the security, if used as an additional authentication factor in a two-factor authentication (2FA) or multi-factor authentication process. Access to the device can be granted (Figure 2 Layer 1) as a result of these operations, and further services are accessible, depending on additional security measures (Figure 2 Layer 2 service-level). Additional security measures in the second layer can be authentication factors independent from the authentication factor of the first layer.

Example: In the first instance, a smartphone has an activated display lock, which can be passed by entering a PIN. Typically, all applications and system services can be accessed. Often login information are stored during the installation and setup process. Access to applications and system services, depending on the data and service sensitivity, can demand a second authentication to the service-level, which can be independent from the authentication factor for unlocking the smartphone. In more detail, a different PIN, password or biometric characteristic can be used to access further services.

The services can be categorized as followed:

- communication and network / online services
- local data services
- device components



*Figure 2 Simplified model of systems using biometrics as an authentication / verification factor. Each lock in the model represents an authentication process, which can consist of a single- or a multi-factor authentication process.*

The security measures for each authentication factor (possession, knowledge, biometrics) can be scaled depending on the required assurance level. The requirements for possession- and knowledge-based authentication factors are defined in BSI TR-03107-1 [3]. The necessary subsystems for a biometric verification system for authentication are shown in Figure 1 and Figure 3 and are further described in subsection 2.2 Exemplary Biometric Authentication / Verification System with its Subsystems.



## 1.5 Overview

### 1.5.1 How to use this Technical Guideline

This technical guideline serves as a “handbook” for hardware manufacturers and software / application developers developing devices with authentication / verification processes using biometrics.

This document considers a generic system, where an authentication process is realised by using biometrics. This process can be built up of different authentication layers (access-level and service-level) as shown in Figure 2. In general, the authentication process of each layer can be executed using a possession-, knowledge- and / or biometrics-based factor.

A successful first layer authentication enables a user to unlock the device. Depending on the security requirements of different applications and services on the device a second authentication layer can be necessary, which can use multiple authentication factors. The strength of the authentication combined methods has to satisfy the overall security requirements. Hardware and software developers have to implement the hardware-, software-components and additional security measures in authentication processes necessary to fulfil the requirements defined for the targeted Biometric Assurance Level (BAL 1, 2 or 3).

Beginning with chapter 2 all requirements containing normative wording are starting with a **bold** identifier. Requirements which have to be considered within the certification process are repeated in normative parts of this Technical Guideline. The used abbreviations are not explained in further detail, but it is possible to divide the requirements in general requirements independent from BALs and requirements specific to reach a certain BAL as specified in this document.

For clarification: a device using a biometric verification as an authentication factor does not need to support all BALs. In consequence, only services and applications up to the supported BAL can be used with the device using biometrics.

The biometric functionality, performance and PAD functionality will be evaluated by an approved testing laboratory. Requirements for test laboratories and evaluators are defined by additional BSI documents<sup>1</sup>. The testing specification is published in a separate document.

### 1.5.2 Target group

This technical guideline allows biometric authentication service- / system-providers and developers to check the requirements defined for a particular BAL in terms of biometric performance and PAD functionality. With this knowledge, developers and manufacturers can set up their biometric authentication system to be compliant to the desired BAL.

### 1.5.3 Target of Evaluation (TOE)

The elements of the TOE have to be defined in the evaluation documentation, including their configuration.

In this Technical Guideline a biometric authentication system and thus the target of evaluation (TOE) consists of all components that are directly required for the biometric authentication process and presentation attack detection (see Figure 1).

For biometric systems operating with various sample acquisition subsystems, e.g., cloud based biometric systems that use a wide range of smartphones or webcams, it is allowed to keep the sample acquisition

---

<sup>1</sup> <https://www.bsi.bund.de/dok/10032172>

subsystem out of the TOE. If a TOE operates with various sample acquisition subsystems, the compatible subsystems have to be specified.

If the TOE has different configurations to fulfil specific BAL, these have to be set and specified accordingly.

However, this technical guideline does not allow testing or certification of single biometric or PAD sub-component of the biometric authentication system (e. g., only the comparison or decision sub-component, see subsection 1.4 and 2.2).

Note: This Technical Guideline does not allow the certification of a single biometric subsystem. As an example: a software or hardware system cannot be certified for a specific BAL e.g., without consideration of the biometric performance.

## 1.6 Key Words

The key words “MUST”, “MUST NOT”, “REQUIRED”, “SHALL”, “SHALL NOT”, “SHOULD”, “SHOULD NOT”, “RECOMMENDED”, “MAY”, and “OPTIONAL” in this document are to be interpreted as described in [8].

- SHALL indicates an absolute requirement, as does MUST and REQUIRED.
- SHALL NOT indicates an absolute prohibition, as does MUST NOT.
- SHOULD indicates a recommendation, as does RECOMMENDED.
- SHOULD NOT or NOT RECOMMENDED indicate the existence of valid reasons in particular circumstances to refrain from implementing technology, organisational measures or actions.
- MAY or OPTIONAL indicates an option.

**Biometrics** is the automated recognition of individuals based on their biological and behavioural characteristics (see [9]).

In this document **Modality** has the meaning of a specific biometric characteristic used in a verification / authentication process.

Example: This document covers biometric verification / authentication with the biometric modalities finger and face.

## 1.7 Key Documents

The key documents considered in this technical guideline are the eIDAS [1] regulation with the German adaption BSI TR-03107 [3]. The technical guideline BSI TR- 03107-1 defines general requirements for authentication systems and procedures.

### 1.7.1 Authentication Methods According to Existing Standards and Documents

For further details about authentication systems and procedures see BSI TR-03107-1 [3]. Other related national and international standards or regulations are listed in Tab. 2.

*Tab. 2 Overview of national and international normative regulations and standards.*

| Document            | Scope                                                                                                                                                          | Version | Release Date   |
|---------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|----------------|
| CEN TS 18212-Series | This Technical Specification series provide a generic framework for the establishment of requirements and their evaluation methodology for biometric products. | 2026    | In preparation |

| Document                 | Scope                                                                                                                                                                                                                                                                                                                    | Version        | Release Date                     |
|--------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|----------------------------------|
| NISTSP800-63-3 [10]      | defines technical requirements in each of the areas of identity proofing, registration, authenticators, management processes, authentication protocols, federation, and related assertions                                                                                                                               | June 2017      | March 2020                       |
| NISTSP800-63 A [11]      | focuses on the enrolment and verification of an identity for use in digital authentication                                                                                                                                                                                                                               | June 2017      | March 2020                       |
| NISTSP800-63 B [12]      | focuses on the authentication of subjects interacting with government systems over open networks, establishing that a given claimant is a subscriber who has been previously authenticated                                                                                                                               | June 2017      | March 2020                       |
| NISTSP800-63 C [13]      | provides technical and procedural guidelines to agencies for the implementation of federated identity systems and for assertions used by federations                                                                                                                                                                     | June 2017      | March 2020                       |
| BSI TR-03121 [4]         | offers a basis for a consistent and comparable quality of public sector applications (biometrics) and for building a common architecture                                                                                                                                                                                 | Version 6.0    | November 2023                    |
| BSI TR-03122 [5]         | specifies test cases for hardware and software components testing according to BSI TR-03121                                                                                                                                                                                                                              | Version 6.0    | November 2023                    |
| BSI TR-03107-1 [3]       | defines requirements around electronic identities for eGovernment. It also contains specific requirements on biometric authentication that should be considered by this guideline                                                                                                                                        | Version 1.1.1  | May 2019                         |
| BSI TR-03159 [14] [15]   | defines the level of assurance (LoA) “substantial” according to eIDAS regulation for mobile identities                                                                                                                                                                                                                   | Draft 2        | August 2019                      |
| ISO/IEC 2382-37:2022 [9] | defines a harmonized vocabulary in the field of biometrics                                                                                                                                                                                                                                                               | Edition 3      | March 2022                       |
| ISO/IEC 19795-1 [16]     | defines requirements on testing and reporting the performance of biometric systems                                                                                                                                                                                                                                       | May 2021       | May 2021                         |
| ISO/IEC TS 19795-9 [17]  | provides guidance for biometric performance testing on mobile devices with local biometric authentication                                                                                                                                                                                                                | December 2019  | December 2019                    |
| ISO/IEC 19989-1 [18]     | defines criteria and methodology for the security evaluation of biometric systems                                                                                                                                                                                                                                        | September 2020 | September 2020                   |
| ISO/IEC TR 24722 [19]    | describes and analyses current practices in multimodal and other multibiometric fusion approaches                                                                                                                                                                                                                        | July 2007      | revised by ISO/IEC TR 24722:2024 |
| ISO/IEC 27001:2013 [20]  | specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system within the context of an organization. It also includes requirements for the assessment and treatment of information security risks tailored to the needs of an organization. | October 2013   | Confirmed in 2019                |

| Document                             | Scope                                                                                                                                                                                                                                                                      | Version      | Release Date      |
|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|-------------------|
| ISO/IEC 30107-1 [6]                  | establishes a framework through which presentation attack events can be specified and detected so that they can be categorized                                                                                                                                             | August 2023  | August 2023       |
| ISO / IEC 30107-3 [7]                | defines testing methodologies for biometric presentation attack detection and the way to report the results.                                                                                                                                                               | January 2023 | January 2023      |
| ISO / IEC 30107-4 [21]               | defines a profile for mobile devices regarding their presentation attack detection capabilities                                                                                                                                                                            | June 2020    | June 2020         |
| ISO / IEC TR 30125 [22]              | Guidance for developing a consistent and secure method of biometric personalization and authentication in a mobile environment for systems procured on the open market.                                                                                                    | May 2016     | Confirmed in 2022 |
| BSI-CC-PP-0063-2010 [23]             | describes the functionality of a biometric system for presentation attack detection regarding the Common Criteria (CC 3.1 R3)                                                                                                                                              | 1.8          | February 2010     |
| IT-Grundschutz Compendium [24]       | contains security recommendations on a wide variety of topics. Detailed advice and safeguards in the implementation guidelines for the IT-Grundschutz modules make it easier for information security officers to implement information security in their day-to-day work. | Edition 2023 | February 2023     |
| BSI Standard 200-1 [25]              | defines the general requirements for an IT security management system (ISMS)                                                                                                                                                                                               | 1.0          | October 2017      |
| BSI Standard 200-2 [26]              | explains how an ISMS can be built based on one of three different approaches                                                                                                                                                                                               | 1.0          | October 2017      |
| BSI Standard 200-3 [27]              | contains all risk-related tasks                                                                                                                                                                                                                                            | 1.0          | October 2017      |
| BSI Standard 200-4 [28]              | covers Business Continuity Management                                                                                                                                                                                                                                      | 1.0          | May 2023          |
| FIDO Biometrics Requirements [29]    | defines the requirements and test specification for the biometric certificate according to FIDO                                                                                                                                                                            | 3.0          | January 2023      |
| PSD 2 [30]                           | European act on definition and application of payment services                                                                                                                                                                                                             |              | January 2016      |
| ETSI TS 103 732 [31]                 | defines a protection profile (PP) for consumer mobile devices, including smartphones and tablets. Security assurance requirements are specified and can be assessed in a Common Criteria security evaluation.                                                              | 1.1.1        | November 2021     |
| ETSI TS 103 732-2 [32]               | defines a PP-Module for Consumer Mobile Device (CMD) which adds the capability to use biometric characteristics for authentication.                                                                                                                                        | 1.1.1.       | October 2023      |
| NIAP Mobile Device Fundamentals [33] | this assurance standard specifies information security requirements for Mobile Devices for use in an enterprise.                                                                                                                                                           | 3.2          | April 2021        |

| Document                                                 | Scope                                                                                                                                                                                                                                                                                                                                                                                                                                | Version                   | Release Date   |
|----------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------|----------------|
| NIAP Mobile Device Fundamentals [34]                     | this assurance standard specifies information security requirements for Mobile Devices for use in an enterprise.                                                                                                                                                                                                                                                                                                                     | 3.3                       | September 2022 |
| BIO-iTC [35]                                             | collaborative PP-Module for Biometric enrolment and verification - for unlocking the device                                                                                                                                                                                                                                                                                                                                          | 1.1                       | November 2022  |
| eIDAS [1]                                                | European act defining assurance levels for electronic identification purposes.                                                                                                                                                                                                                                                                                                                                                       |                           | July 2014      |
| eIDAS 2.0 [2]                                            | Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework                                                                                                                                                                                                                                        |                           | May 2024       |
| eCH-0170 [36]                                            | compares different standards and regulations related to digital identities                                                                                                                                                                                                                                                                                                                                                           | 2.0                       | September 2017 |
| CCMB-2017-04-001 [37]<br>Also published as ISO/IEC 15408 | This part of the CC establishes the general concepts and principles of IT security evaluation and specifies the general model of evaluation given by various parts of the standard, which in its entirety is meant to be used as the basis for evaluation of security properties of IT products.                                                                                                                                     | Version 3.1<br>Revision 5 | April 2017     |
| CCMB-2017-04-002 [38]<br>Also published as ISO/IEC 15408 | This part of the CC defines the required structure and content of security functional components for the purpose of security evaluation. It includes a catalogue of functional components that will meet the common security functionality requirements of many IT products.                                                                                                                                                         | Version 3.1<br>Revision 5 | April 2017     |
| CCMB-2017-04-003 [39]<br>Also published as ISO/IEC 15408 | This CC Part 3 defines the assurance requirements of the CC. It includes the evaluation assurance levels (EALs) that define a scale for measuring assurance for component TOEs, the composed assurance packages (CAPs) that define a scale for measuring assurance for composed TOEs, the individual assurance components from which the assurance levels and packages are composed, and the criteria for evaluation of PPs and STs. | Version 3.1<br>Revision 5 | April 2017     |
| CCMB-2017-04-004 [40]<br>Also published as ISO/IEC 18045 | The Common Methodology for Information Technology Security Evaluation (CEM) is a companion document to the Common Criteria for Information Technology Security Evaluation (CC). The CEM defines the minimum actions to be performed by an evaluator in order to conduct a CC evaluation, using the criteria and evaluation evidence defined in the CC.                                                                               | Version 3.1<br>Revision 5 | April 2017     |
| CCMB-2022-11-001 [41]                                    | This part of the CC establishes the general concepts and principles of IT security evaluation and specifies the general model of evaluation given by various parts of the standard, which in its entirety is meant to                                                                                                                                                                                                                | CC:2022<br>Revision 1     | November 2022  |

| Document                                                               | Scope                                                                                                                                                                                                                                                                                                                                                                                                                                | Version                | Release Date  |
|------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------|---------------|
| Also published as<br>ISO/IEC 15408-1:2022                              | be used as the basis for evaluation of security properties of IT products.                                                                                                                                                                                                                                                                                                                                                           |                        |               |
| CCMB-2022-11-002 [42]<br><br>Also published as<br>ISO/IEC 15408-2:2022 | This part of the CC defines the required structure and content of security functional components for the purpose of security evaluation. It includes a catalogue of functional components that will meet the common security functionality requirements of many IT products.                                                                                                                                                         | CC:2022<br>Revision 1  | November 2022 |
| CCMB-2022-11-003 [43]<br><br>Also published as<br>ISO/IEC 15408-3:2022 | This CC Part 3 defines the assurance requirements of the CC. It includes the evaluation assurance levels (EALs) that define a scale for measuring assurance for component TOEs, the composed assurance packages (CAPs) that define a scale for measuring assurance for composed TOEs, the individual assurance components from which the assurance levels and packages are composed, and the criteria for evaluation of PPs and STs. | CC:2022<br>Revision 1  | November 2022 |
| CCMB-2022-11-004 [44]<br><br>Also published as<br>ISO/IEC 15408-4:2022 | This document describes a framework that can be used for deriving evaluation activities from work units of the CEM and grouping them into evaluation methods (EMs). In addition, a standardized framework for specifying objective, repeatable and reproducible evaluation methods and evaluation activities is introduced in this document.                                                                                         | CC:2022<br>Revision 1  | November 2022 |
| CCMB-2022-11-001 [45]<br><br>Also published as<br>ISO/IEC 15408-5:2022 | This document provides packages of security assurance and security functional requirements that have been identified as useful in support of common usage by stakeholders.                                                                                                                                                                                                                                                           | CC:2022<br>Revision 1  | November 2022 |
| CCMB-2022-11-006 [46]<br><br>Also published as<br>ISO/IEC 18045:2022   | This document defines the minimum actions to be performed by an evaluator in order to conduct a CC evaluation, using the criteria and evaluation evidence defined in the CC                                                                                                                                                                                                                                                          | CEM:2022<br>Revision 1 | November 2022 |

## 2 Biometric Verification as an Authentication Factor (Informative)

To achieve conformance with different standards and normative texts, this technical guideline needs to consider single- and multi-factor authentication processes. Possible authentication factors are based on possession, knowledge or biometrics. A detailed description for possession- and knowledge-based authentication factors can be found in BSI TR-03107-1 [3].

This chapter includes descriptions, definitions, requirements and recommendations. The intention of the following chapters is to introduce different concepts and possibilities to implement biometrics in an authentication / verification process. Further, a generic biometric system with its subsystems is briefly described. The overall intention of this chapter is to introduce a general biometric system with its different subsystems, possible attack vectors to attack such a system and established international standards regarding metrics for performance evaluation and comparison metrics for Presentation Attack Detection (PAD) mechanisms, which are not typically used in a security evaluation outside of biometric systems.

With respect to the certification process the following subchapters are **INFORMATIVE**, even if normative key words are used. In future versions of this technical guideline this chapter can be changed to a normative chapter.

### 2.1 Authentication Factors

Authentication factors can be grouped into three categories: knowledge, possession and biometrics. In other words, these three groups can be described as something you know, something you possess and something you are. The categories possession and knowledge are more precisely defined and described with their corresponding requirements in BSI TR-03107-1 [3]. Biometrics as an authentication factor is addressed in this technical guideline in the following sections.

A general ranking of the different authentication factors across all authentication categories is not feasible, because every factor has its particular requirements regarding environment, usability, costs and the necessary level of security. The major advantage of biometrics, the convenience that natural features of a person cannot be lost or forgotten, is also its biggest disadvantage.

Due to the limited number of biometric characteristics, it is not possible to change biometric features arbitrarily often if a sample is stolen. A possibility to hamper attacks with stolen biometric references / templates can be the use of template protection mechanisms. Suitable methods are still under development and investigation.

Therefore, secure storage solutions are of particular importance, but not part of this technical guideline.

In addition, the probabilistic character of biometric methods gives rise to the possibility that persons with similar biometric characteristics (for some modalities observable on twins) are recognized as the genuine data subject.

When aiming for a certain assurance level, single factor, multi-factor or multi-stage authentication processes can combine the authentication factors from the three categories in accordance with specific technical guidelines and / or other related standards.

#### 2.1.1 Biometric Verification for Authentication

Biometrics can be used as an authentication factor in a single- and a multi-factor authentication process.

In the current version of this technical guideline, the biometric modalities finger and face are considered. Additional biometric modalities like iris, retina or veins may be added in future versions. In future applications, dynamic / behaviour-based biometric modalities like voice or motion gait can be implemented to extend the number of usable biometric modalities.

In comparison to knowledge- and possession-based factors, where the comparison between the input and the true secret is deterministic, biometrics is a probabilistic method. The biometric input slightly changes with every presentation (e.g., position, tilt, angle) and, in addition, changes over time (e.g., ageing, injuries) or temporarily (e.g., injuries, cosmetics). Therefore, thresholds are necessary to distinguish between a valid presentation by an authorized individual and attempted fraud.

Possible attack vectors within a biometric authentication system are shown in Figure 1 in chapter 1.2 Scope.

#### 2.1.1.1 Biometric Verification in Single-Factor Authentication

In a single-factor authentication process a single authentication factor from the category knowledge, possession or biometrics can be used.

Note: Depending on the field of application, the use of biometrics can be excluded.

Example: BSI TR-03107-1 [3] (Electronic Identities and Trust Services in E-Government) states that biometrics "SHALL NOT" be used as a single factor (see specific application modules for BSI TR-03107-1).

**GEN-SFA-01:** The authorized data subject SHOULD have exclusive access to the authentication factor.

Note: GEN-SFA-01 is hard to apply due to the general accessibility of biometric characteristics like face images in, e.g., social media.

Note: To improve the biometric performance and to increase the effort an attacker needs to create successful presentation attack instruments (PAI), authentication modalities, e.g., finger and face and instances, e.g., thumb and index may be combined (see 2.1.1.2). A PAI is, among other things, an artificial object to represent biometric characteristics to a suitable capture device.

Example: A door lock might be used with a biometric authentication factor as a single authentication factor.

#### 2.1.1.2 Multibiometrics

Multibiometrics can be used to improve the biometric performance and security of a biometric system. Therefore, different approaches can be followed to achieve a lower false acceptance rate (FAR) and a higher resistance against presentation attacks.

In a multi-modal authentication scheme, different biometric modalities (e.g., face and finger) can be combined during an authentication process, when biometrics is used. Even if several biometric characteristics and modalities are used, biometrics is still a single authentication factor and can be combined with a possession- or knowledge-based factor for a multi-factor authentication process, see GEN-MFA-03.

If only a single sensor for a single modality is available at a device, the biometric performance can be enhanced with the multi-instance approach. Multiple biometric characteristics of the same modality are used for the verification. An addition to the multi-instance method can be the multi-presentation scheme, where the same biometric characteristic is presented multiple times to the capture device.

If possible, a biometric sample can be captured with multiple different sensors at the same time.

Example: An example is the acquisition of a facial image with a standard camera to capture a 2D image and an additional camera, which records depth information.

The multi-algorithmic scheme analyses the same dataset with different algorithms.



Multibiometrics can be divided into five sub-categories, which are defined in ISO/IEC TR 24722:2024 [19]:

- multicharacteristic-type – these systems take input from single or multiple sensors that capture two or more different types of biometric characteristics.
- multialgorithmic biometric systems – usage of two or more distinct algorithms for processing the same biometric sample
- multiinstance biometric systems – usage of at least two instances of the same biometric characteristics. e.g., left and right iris or left and right index
- multisensorial biometric systems – using multiple capture devices for capturing samples of one biometric characteristic
- multipresentation – using either multiple presentation samples of one instance of a biometric characteristic or a single presentation that results in the capture of multiple samples

Multibiometrics can be used to improve the performance of biometric systems in terms of error rates. If multi-modal biometric systems are used, data structures of several parts of ISO/IEC 39794 [47] can be involved in an authentication process. Multi-instance or multi-presentation data are stored in several biometric representations that are contained in one record.

#### 2.1.1.3 Biometric Verification in Multi-Factor Authentication / Verification

In a multi-factor authentication process, authentication factors of different categories (knowledge, possession, biometrics) can be used to achieve a more secure authentication.

**GEN-MFA-01:** The authorized data subject SHOULD have exclusive access to the biometric authentication factor.

Note: GEN-MFA-01 is hard to apply due to accessibility of face images in, e.g., social media and general accessibility of biometric characteristics.

**GEN-MFA-02:** The authorized data subject SHALL have exclusive access to the authentication factors from the categories possession and knowledge.

**GEN-MFA-03:** At least two factors SHALL belong to different categories.

Note: To improve the biometric performance and to increase the effort an attacker needs to create successful PAI, authentication modalities and instances can be combined (see 2.1.1.2). Still, at least two authentication factors of different categories take part in the authentication process.

#### 2.1.1.4 Biometric Verification in Multi-Stage Authentication

A multi-stage authentication is the sequential use of single- and / or multi-factor authentication processes. In contrast to multi-factor authentication, the different stages in multi-stage authentication are independent of each other and different stages may belong to the same authentication factor category (knowledge, possession, biometrics).

**GEN-MSA-01:** In case biometric verification is integrated in a Multi-Stage Authentication the biometric characteristic used for each stage SHALL be a different for each stage.

Examples:

- At the first stage, the access-level, access to a smartphone can be gained with a single biometric modality, e.g., face image or fingerprint. To access an application on the smartphone, the service-level, a second biometric characteristic is used. So far, a single biometric characteristic is often used in multi-stage authentication.

- Access to a personal computer is protected by a password / PIN, which would be the first stage, the access-level, of the authentication. To get access to a specially secured file, the service-level, a different password / PIN is recommended to decrypt and access the file.

Note: If more than one biometric verification is integrated into a Multi-Stage Authentication, the biometric characteristic used for each Stage SHALL be different for each Stage.

### 2.1.1.5 Error Rates in Biometrics

In this section, a general introduction to error rates used in biometrics is given and is **INFORMATIVE**. The terms and definitions are in agreement with the metrics for presentation attack detection in ISO / IEC 30107-3:2023 [7] and the description of metrics for the evaluation of biometric performance in ISO/IEC 19795-1:2021 [48].

1. The false match rate (FMR) is the proportion of the completed biometric non-mated comparison trials that result in a false match.
2. The false non-match rate (FNMR) is the proportion of the completed biometric mated comparison trials that result in a false non-match.

Often the terms FMR / FNMR and FAR / FRR are used interchangeably, but there is a significant difference between them. On the one hand, FMR and FNMR can be related to the matching algorithm (algorithm level error). On the other hand, the FAR and FRR also take into account those attempts for which the system fails to generate a signal or fails to extract features. Therefore, the FAR and FRR describe the system as a whole and not only the performance of the system's algorithm.

The biometric verification subsystem includes hardware and software. Therefore, the FAR and FRR have to be applied. Beside the overall error rates, specific error rates for PAD can be defined, but are not relevant for the vulnerability analysis in this technical guideline:

1. The attack presentation classification error rate (APCER) is defined by the proportion of attack presentations using the same PAI species which are incorrectly classified as genuine presentations in a specific scenario.
2. The bona fide presentation classification error rate (BPCER) is the proportion of bona fide presentations incorrectly classified as presentation attacks in a specific scenario. In a bona fide attempt, a valid identity claiming is performed with the genuine biometric characteristics belonging to this identity.
3. The attack presentation non-response rate (APNRR) is the proportion of attack presentations using the same PAI species that cause no response at the PAD subsystem or data capture subsystem.
4. The bona fide presentation non-response rate (BPNRR) is the proportion of bona fide presentations that cause no response at the PAD subsystem or data capture subsystem.
5. The attack presentation acquisition rate (APAR) is the proportion of attack presentations using the same PAI species from which the data capture subsystem acquires a biometric sample of sufficient quality.
6. The impostor attack presentation match rate (IAPMR) is the proportion of impostor attack presentations using the same PAI species in which the target reference is matched.
7. The concealer attack presentation non-match rate (CAPNMR) is the proportion of concealer attack presentations using the same PAI species in which the reference of the concealer is not matched. A concealer attack is an attack with the aim to evade from a recognition process e.g., by changing the facial expression or masquerade.
8. The impostor attack presentation identification rate (IAPIR) is the proportion of impostor attack presentations using the same PAI species in which the targeted reference identifier is among the

identifiers returned or, depending on the intended use case, at least one identifier is returned by the system.

9. The concealer attack presentation non-identification rate (CAPNIR) is the proportion of concealer presentation attacks using the same PAI species in which the reference identifier of the concealer is not among the identifiers returned or, depending on the intended use case, in which no identifiers are returned.

Note: PAD evaluation and their evaluation and metrics are defined in the EG for this technical guideline, without the use of rates, which have to be used only for research-based comparisons.

## 2.2 Exemplary Biometric Authentication / Verification System with its Subsystems

Due to the variety of applications and technologies, where biometrics plays an important role, it is hard to make general statements about what constitutes an optimal biometric system. However, all systems using biometrics for authentication / verification purposes have many components (see Figure 3) in common to ensure the required functionalities. A subject's biometric characteristics are captured by a capture device. Several sensors can be implemented to realise a Presentation Attack Detection (PAD) without necessarily contributing to the image creation for biometric comparison. The information is transmitted to the signal processing subsystem, where an image quality assessment is done, PAD is executed and biometric features are extracted. When the biometric characteristic is captured during an enrolment process, a biometric reference will be created. The biometric reference can consist of one or more stored biometric samples or biometric templates to serve as a reference for future authentication processes. In an authentication process, the biometric probe is compared in the comparison subsystem with the biometric reference created in the enrolment process. As a result of the comparison, a score quantifying the similarities between the biometric reference and biometric probe is calculated. A decision on the biometric verification request for the authentication is made based on the comparison score, the corresponding threshold and the PAD score and PAD threshold. The threshold can be adjusted to achieve the required biometric performance for a certain BAL.

Beside the pure technical description of the biometric system, organisational measures can be used to decrease the probability to successfully perform an attack on the biometric system.

**GEN-BTF-01:** The TOE SHALL implement measures to prevent brute force attacks.

**GEN-BTF-02:** The product manufacturer SHALL justify the choice of measures to prevent brute force attacks with respect to the targeted BAL.

**GEN-BTF-03:** The testing laboratory SHALL evaluate the measures and take them into account within the evaluation result.

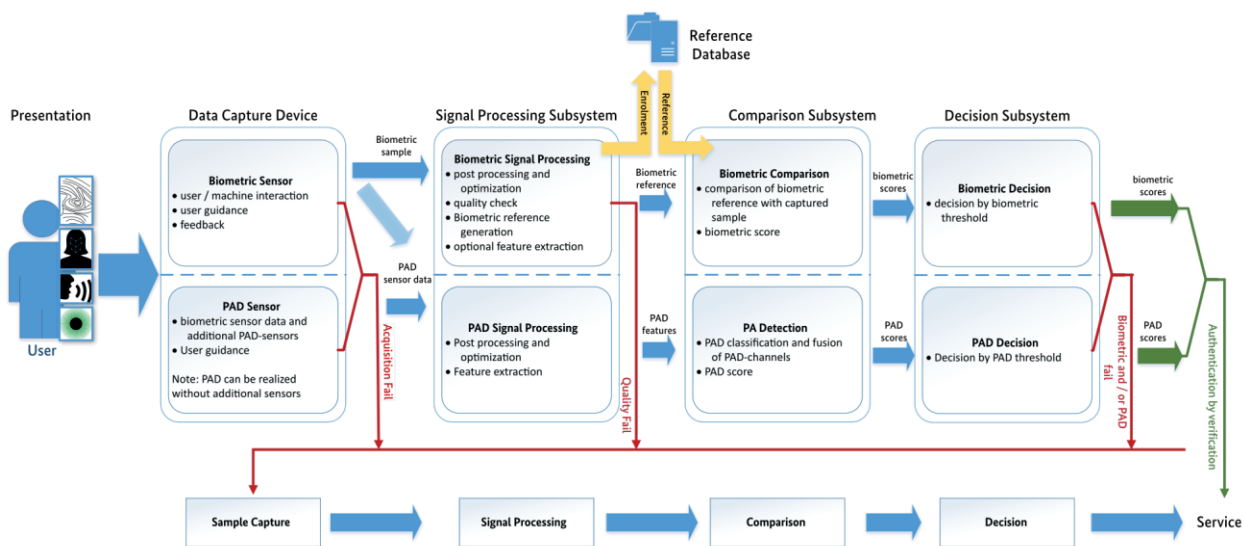


Figure 3 Schematic drawing of components in a generic biometric system for authentication purposes. Adapted from [49].

In addition to security related features of each subsystem, the system's security can be improved by adding other security measures.

**GEN-SEC-01:** The biometric verification / authentication SHOULD have a feature for abuse detection.

Example: Beside functionalities directly related and provided by the subcomponents other functionalities can be implemented to secure the biometric system, e.g., manipulation detection.

Note: For a smartphone such a manipulation detection can be integrated e.g. via root detection mechanisms or other measures.

**GEN SEC-02:** The biometric authentication subsystem SHOULD detect suspicious deviations from normal behaviour using heuristic methods.

Example: Such a suspicious deviation from normal behaviour can be authentication / verifications processes from different geolocations in unrealistic short time intervals.

## 2.2.1 Biometric Sample Capture Subsystem

The acquisition hardware assigned to the sample capture device captures a signal from the presented biometric modality and passes the raw signal with all presented biometric characteristics to the signal processing subsystem.

In addition to the biometric capture device used for the image capture process, optional components can be implemented for PAD.

The acquisition hardware for biometrics is not limited to any technique, but the biometric verification subsystem for authentication as a whole has to fulfil the requirements of the BAL required (1, 2 or 3).

## 2.2.2 Signal Processing Subsystem

The signal processing subsystem performs a quality check of the captured biometric data prior to further post processing and optimization steps. The essential biometric features are recognized and extracted. Some algorithms work without a feature extraction and use a biometric sample directly for the comparison step. In case of multiple biometric samples acquired from different body parts (multiple fingers on a single

scanner), a segmentation of these biometric samples can be necessary, if the modality does not correspond to the body part as a whole (e.g., complete hand).

During the enrolment step, a biometric reference is created and stored in the biometric enrolment database for comparison in subsequent biometric verification requests for authentication. During an authentication process, extracted and processed biometric features are transmitted to the comparison subsystem.

#### 2.2.2.1 Presentation Attack Detection (PAD)

A PAD subsystem is a hardware and / or software system that implements a PAD mechanism and makes an explicit declaration regarding the detection of presentation attacks (PA). Results of the PAD mechanism are accessible to the evaluator and are an aspect of the evaluation. In case of a positive PAD (a PA was detected) it will be decided if the biometric sample will be presented again or a fall-back to a different authentication factor will be performed.

**GEN-PAD-01:** PAD SHALL be performed for every single biometric presentation.

**GEN-PAD-02:** PAD SHALL be synchronous to the biometric data acquisition and comparison process<sup>2</sup>.

**GEN-PAD-03:** PAD scores and their thresholds SHALL be accessible to the evaluator.

Note: A biometric PAD subsystem can be based on more than a single evidence, which can lead to several scores or a single score. For a time and cost-efficient evaluation of the biometric system evidences and scores are necessary to evaluate the system within the given timeframes for the evaluation.

Note: No access to such scores can affect the evaluation time.

**GEN-PAD-04:** PAD scores SHALL be designed in a manner, which are useful for evaluating biometric systems, e.g., via Hill-Climbing Attacks.

**GEN-PAD-05:** The PAD scores SHALL be inaccessible outside the evaluation process.

Note: The PAD mechanism makes a score accessible to the evaluator, which can be used by the evaluator during the pre-evaluation step to improve the presentation attack instruments. The corresponding requirements are defined in EG PRE-PRO-01X and EVA-GEN-01 For example, a score which is only 0 or 1 is not useful and does not provide sufficient information to the evaluator.

**GEN-PAD-06:** PAD evaluation SHALL be performed based on the evaluation metrics defined in the BSI Evaluation Guidance of this Technical Guideline.

#### 2.2.2.2 Quality Control Subsystem

The quality control process decides if the quality of the captured biometric sample is sufficient for further processing steps.

**GEN-QCS-01:** Quality control SHALL be performed for every single biometric presentation.

**GEN-QCS-02:** If the quality is not sufficient, the biometric characteristic SHALL be presented again.

Note: Depending on the policy and the integration of measures to prevent brute force attacks presentation attempts without sufficient quality can be counted as an attempt.

---

<sup>2</sup> If the biometric capture process and the PAD are working subsequently, it might be possible that at first the presentation of an artefact results in a positive biometric comparison and afterwards an attacker presents his own face to circumvent the PAD mechanism, which might be realized via a liveness detection, as a subgroup of possible PAD mechanisms.

**GEN-QCS-03:** It SHOULD be verified that the external presentation conditions cannot induce a false acceptance.

Example: A saturated detector can lead to a false acceptance.

**GEN-QCS-04:** A Quality score SHALL be accessible to the evaluator, if used in the decision process.

#### 2.2.2.3 Segmentation Subsystem

**GEN-SEG-01:** The image SHALL be segmented into parts containing the single biometric instances.

Note: An exception can be a biometric presentation where the complete biometric characteristic is taken into account (e.g., complete hand).

#### 2.2.2.4 Feature Extraction Subsystem

After a passed quality control, the biometric features are extracted from the biometric sample and transmitted to the comparison subsystem.

Note: During the enrolment process extracted features are not transmitted to the comparison subsystem. Instead, the features are stored in a biometric reference.

**GEN-FES-01:** The feature extraction SHOULD work unidirectional.

**GEN-FES-02:** It SHOULD NOT be possible to reconstruct the original biometric sample from the extracted features.

Suitable template protection methods are e.g., defined in ISO/IEC 24745 [50].

### 2.2.3 Reference Creation

If the biometric characteristic is presented during an enrolment process, a biometric reference is created. The created reference will be transmitted to the biometric enrolment database.

#### 2.2.4 Biometric Enrolment Database

**GEN-BED-01:** The storage of biometric references SHOULD work in accordance to ISO/IEC 24745 [50].

**GEN-BED-02:** The biometric enrolment database SHALL provide sufficient protection of the biometric reference data.

**GEN-BED-03:** Manipulation, unauthorized insertion or deletion of templates SHALL be impossible.

**GEN-BED-04:** Biometric samples stored as a biometric reference SHALL be protected against reconstruction towards back to the biometric characteristics.

**GEN-BED-05:** The biometric template protection SHOULD meet the requirements set out in ISO/IEC 24745 [50].

The performance testing of a biometric template protection system is described in ISO/IEC 30136 [51].

Note: The security of a biometric enrolment database is not in the focus of this technical guideline. Nevertheless, the mentioned features defined in the referenced ISO standards are important to achieve secure biometric authentication systems, where the biometric information is securely stored.

During the enrolment process the TOE can give information regarding the enrolment process, including a modality specific re-enrolment period, how to handle a continuous refresh of the reference and how to deal with automatic compensation algorithms if used.

**GEN-ENR-01:** The user **SHOULD** be informed to execute a re-enrolment within a modality typical time range.

Note: The recommended time range for a re-enrolment for the modality fingerprint is about 1 year and for a facial recognition about 6 months.

**GEN-ENR-02:** In case an automatic update of the biometric reference is implicitly performed with every successful authentication / verification, this **SHALL** be made transparent to the user.

**GEN-ENR-03:** The biometric system **MAY** inform the data subject if any compensation algorithms against aging effects are implemented.

### 2.2.5 Comparison Subsystem

The comparison subsystem compares the biometric probe of a biometric reference enrolled by a genuine data subject with the biometric features extracted from the biometric sample presented by the identity claimant. The comparator generates a score, which is an assessment of the similarity of the sample and the reference. This score can be a similarity score, in combination with a predefined threshold, this is the basis for the comparison decision for this modality.

**GEN-COM-01:** The biometric comparison score **SHALL** be accessible to the evaluator during the pre-evaluation process.

**GEN-COM-02:** The biometric comparison threshold **SHALL** be known by the evaluator for the evaluation process.

**GEN-COM-03:** The biometric comparison score **SHALL** enable the evaluator to adjust PAIs to exceed the required comparison threshold.

**GEN-COM-04:** The biometric comparison score **SHALL** be inaccessible outside the evaluation process.

The generated numeric comparison score is transmitted to the comparison decision subsystem.

Note: The comparison subsystem makes a score accessible to the evaluator, which can be used by the evaluator during the pre-evaluation phase to create a presentation attack instrument. For example, a biometric comparison score that is only 0 or 1 is not sufficient for an evaluator to create and improve presentation attack instruments for the evaluation.

### 2.2.6 Decision Subsystem

During the authentication process, the received numeric comparison score is compared to a pre-defined threshold. If the numeric value is above the threshold, verification is successful, and this information is passed on to the service. If the score is below the threshold, the verification of the biometric sample has failed.

**GEN-DES-01:** For a positive verification / authentication the biometric comparison score **SHALL** be equal or higher than the biometric threshold and the PAD subsystem **SHALL** classify the attempt as Bona-Fide.

**GEN-DES-02:** During an authentication process the TOE **SHALL** only allow a certain limit of biometric authentication attempts, defined for the targeted BAL.

**GEN-DES-03:** If the upper limit for biometric presentation attempts is exceeded, defined by the target BAL or policies, a fall-back to a different verification / authentication method on the at least same or higher BAL or related eIDAS [2] possession- or knowledge-based verification / authentication mean **SHALL** be performed.

## 2.2.7 Communication of the Biometric Verification / Authentication Result

The biometric system can pass the verification result to an external service, application or system via an application programming interface, hardware interface or protocol interface (see Figure 3).

## 2.3 Attack Vectors on a Biometric System

In general, attack vectors are mechanisms and methods to overcome security features and compromise a system. The consequence is a partial or complete control of the system / device by an attacker. That means, an attacker can fully use all or some of the services mentioned in section System Model 1.4, like a valid user. The device can contain many different services and interfaces that may give rise to unauthorised access. The attack vectors in a generic device with a biometric authentication subsystem are described below.

Current biometric systems, e.g., smartphones and tablets, mainly use two types of biometric modalities for verification, namely face and finger. Therefore, after a general description, the attack vectors targeting the two biometric verification modalities face and finger for authentication processes are described.

A potential attacker can use several attack vectors to target the biometric verification subsystem:

- Presentation of artificial / augmented biometric characteristics at the capture device level
- Physical Adversarial Attacks against Face Recognition Systems [52]
- Recording and replay or manipulation of transmitted information within or between the subsystems
- Direct manipulation of the underlying algorithms (e.g., for template creation, feature extraction or similarity score calculation)
- Insertion, deletion, modification of biometric templates at the biometric enrolment database
- Threshold manipulation regarding similarity scores and PAD functionality

Figure 1 provides an overview of the different attack vectors and the components where a potential manipulation can be done. The scope of this technical guideline is the Presentation Attack (PA) at the Sensor (arrow 1, grey dashed box).

At this point we want to emphasize that generation, alteration or modification of presentation attack instruments via artificial intelligence is in scope by this technical guideline.

This also includes techniques like Deepfakes if they are used to perform presentation attacks, e.g., presenting such images or videos to the sensor of a biometric system.

Deepfakes can be used in terms of injection attacks, in Figure 1, e.g., visualized as attack vector 2 “Modify Biometric Sample”. Currently this attack vector is out of scope in this technical guideline.

All attack vectors are briefly described below for a generic biometric system.

### 2.3.1 Attack Against the Biometric “Sample Acquisition”

This attack vector corresponds to arrow 1 in Figure 1, which is highlighted by the dashed grey line and grey background. The direct attack at the biometric sample acquisition / capture device, by presenting an artefact (e.g., a replica of the biometric characteristic), is a possibility to attack the device without further knowledge of subsequent signal transmission, signal processing, biometric enrolment database and evaluation steps, which leads to a final comparison decision of a successful or unsuccessful verification.

The biometric data capture subsystem is necessary to capture the data set for the enrolment step and for every attempt at verification for authentication.



In addition to the image capture device / sample generator, further sensor channels for a potential PAD mechanism can be implemented.

### 2.3.1.1 Presentation Attack

According to ISO 30107-3 [7], a presentation attack is the attempt to present a biometric characteristic or object to the biometric data capture subsystem with the goal of interfering with the operation of the biometric system.

#### 2.3.1.2 Presentation Attack Instrument (PAI)

For a presentation attack an attacker presents a presentation attack instrument (PAI) with the biometric characteristics of a genuine / authorised data subject to the capture device.

To overcome the PAD mechanism, special presentation attack instruments (PAI), e.g., based on different materials can be used, which would not be detected as an artificial material and therefore not as an PAI.

**ATT-PAI-01:** A presentation attack instrument (PAI) SHOULD be created using a common production method fitting the biometric modality to attack.

Note: In particular, for BAL 2 and 3, where an evaluator is free in creating new attack instruments within the defined attack potential, uncommon production methods can play an important role to evaluate the biometric system in a proper manner.

**ATT-PAI-02:** The creation procedure SHALL be based on the assumption of a worst-case scenario.

Note: This means an attacker has access to the best and modality dependent data of the biometric subject to create the PAI.

Typically, the first step is the acquisition of the biometric characteristic. Latent analogue samples stemming from the target biometric characteristics can be found for example on the device to attack itself or can be publicly available on the internet or be created by recording videos, images or other information sources. The quality of the biometric representation obtained can be improved via post-processing steps. A digitized version of the biometric characteristic can be translated into different PAIs made of different materials. This easiest kind of attack includes 2D projection / images of the biometric sample. To achieve PAIs of a higher quality, high-quality images (2D) and 3D data sets are necessary. Using these data sets, it is also possible to create artificial 3D PAIs (masks, 3D finger artefacts). Depending on the materials used and the sensor technology embedded in the capture device, the artificial PAI will create an image / signal at the biometric data capture subsystem or it will fail to do so. Therefore, it is necessary to implement PAD to detect artificial PAIs, which create a “Biometric sample” signal at the capture device.

Further information on the production of presentation attack instruments (PAI) can be found in the Evaluation Guidance for this Technical Guideline.

## 2.3.2 Information Transmission Attack

Information has to be transmitted (see Figure 1 arrow 2, 4, 6, 8) both between different subsystems in the biometric system and between processes within individual subsystems. A potential attacker can manipulate the information at each transmission in order to influence the final decision. As an alternative, the attacker can store the information from a genuine authentication process and can replay this information to bypass the input of the biometric sample presented at the capture device.

Based on the signal recorded during a genuine authentication process, this kind of replay attack can be performed between every pair of subsystems in order to achieve successful authentication.

### 2.3.3 Signal Processing Subsystem Attack

The signal processing subsystem has multiple functions (PAD, quality control, feature extraction and segmentation). During an enrolment step, the biometric reference is created within the signal processor.

Typically, PAD is one of the first steps in the signal processing subsystem. At this point, the attacker can change the PAD decision by tampering with the PAD subsystem. The signal of the PAI presented to the capture device is recognized for further processing.

Quality control might be deactivated by an attacker, which facilitates the usage of an artificial “master key” which would not have passed quality control.

A potential attacker can likewise modify the feature extraction. This can be used to generate biometric features, which are independent from or strongly uncorrelated with the presented biometric sample. Therefore, the verification can be granted or denied for arbitrary persons.

This can also influence the process of reference creation, which is executed inside the signal processing subsystem. The reference might be based on biometric features unrelated to the presented biometric sample.

### 2.3.4 Biometric Enrolment Database Attack

After successful enrolment, the created biometric reference is stored in the biometric enrolment database. Typically, the database does not store the captured biometric reference itself, but rather a template containing the biometric features that are recognized and extracted. These steps are performed in the signal processor subsystem.

At the biometric enrolment database level, different attacks can be executed. On the one hand, the attacker can add or modify biometric templates if the data format in which the biometric references are stored is known. On the other hand, the attacker can delete stored biometric references.

### 2.3.5 Comparison Subsystem Attack

The comparator in the comparison subsystem compares the stored biometric reference of the claimed identity with the biometric probe from the claimant. The comparator computes a numeric comparison score based on a specific metric. The comparator can be manipulated by an attacker to generate a false comparison score.

#### 2.3.5.1 Zero Effort Impostor Attack

In case of the zero effort impostor attack an attacker presents his biometric characteristics. The biometric probe will be compared against the biometric reference enrolled by an authorised data subject.

If the sensitivity / specificity of the capture device or the biometric comparison algorithm is not high enough or biometric samples contain intrinsically comparable biometric features, presented biometric characteristics can impersonate another individual.

No PAD will be successful against this type of attack because, e.g., a real finger from a live person is presented to the capture device.

Therefore, the matching algorithm has to operate with a sufficient performance, e.g., by finding a sufficient numbers of matching biometric features to obtain a biometric performance that matches the requirements of the desired BAL.

### 2.3.6 Comparison Decision Subsystem Attack

The decision subsystem receives the comparison score from the comparison subsystem and decides, based on a pre-defined threshold, if the score is sufficiently high to accept it. This decision is binary. The final decision on the verification outcome for authentication is based on the verification policy. The verification decision for authentication is passed to the calling service.

An attacker can proceed in two different ways to influence the final verification decision. Either the threshold can be manipulated in order to obtain a positive decision on verification, or the final decision after the comparison between score and threshold is manipulated.

## 2.4 Recommendation and Considerations when Using Biometric Modalities for Authentication / Verification Process

Integration of biometrics can improve the user experience and usability of authentication / verification processes, but different challenges can occur while using different biometric modalities. Therefore, to improve the overall usability of biometrics in combination with more secure biometric authentication / verification processes is still challenging.

### 2.4.1 Modality Finger

Fingerprints can be captured based on different technologies, e.g. ultra-sonic, optical, photo, resistance, heat transfer, capacity, mechanics, which are either contactless or require the fingers to be in contact with a surface. Depending on the technology used, acquired signals or images can differ from each other, but still remain unique and can be used to verify and distinguish different individuals. Therefore, it is beneficial to consider the following key points for implementing fingerprints in a biometric verification / authentication process.

- The user is advised about the purpose of authentication / verification.
- It is favourable to use different biometric modalities and instances within an authentication / verification procedure, e.g. not for authentication and transaction release; or not for device unlocking and authentication within a procedure based on several steps with integrated biometrics for authentication / verification.
- For an improved user experience developers and integrators can implement hints regarding the biometric modality and instance, especially, in biometric systems where multiple biometric instances and modalities can be enrolled in the system.  
Such functionality can make it easier to remember which biometric modality or instance was used for the enrolment.

Note: Using different fingerprints to unlock different applications can improve the security of the biometric system. For an attacker it will be more challenging to acquire biometric samples for each finger needed to gain access.

E.g. it is unlikely that a smartphone is controlled with a middle finger of a hand. Therefore, it will be more challenging for an attacker to find residual latent fingerprints directly on the device in a sufficient quality and completeness.

- The amount of moisture on the finger(s) affects the sensor's ability for successful capture [12].
- Additional factors can influence the fingerprint capture quality:
  - age

- gender
- occupation, e.g. users handling chemicals or working extensively with their hands may have degraded friction ridges [12].
- Differences in environmental conditions can affect recognition accuracy and PAD performance.

A rejected authentication by verification is not necessarily caused by a fraudulent use of biometrics. Rejections can also originate from usage problems or special situations, e.g. changing locations or devices.

### **Presentation Condition**

Depending on the capture device technology used, the conditions to obtain a fingerprint of sufficient quality can differ. Such external conditions could be strong lighting on the capture device or, more generally, electromagnetic waves. Other external conditions can be temperature or humidity, which can have an influence on the capture device. Therefore, the technologies used can be more or less sensitive under different circumstances or can differ in image / signal quality independent from the captured sample.

### **Presentation Attack / Threat**

Different capture device technologies are available on the market. To achieve a valid biometric verification decision between the enrolled fingerprint and the artefact finger used as an attack vector, several steps during the authentication process can be targeted. An attack vector, which is directly accessible without any deeper knowledge about the signal transmission or access to the other subsystems, is the presentation of a PAI to the biometric data capture subsystem.

For possible attack vectors, see Figure 1.

## **2.4.2 Modality Face**

State-of-the-art devices provide the possibility to capture face images via different camera systems in the enrolment step. The enrolled face image can be compared against a probe image acquired for verification purposes.

The process of enrolment and authentication / verification can be influenced by several factors:

- User can wear garment and / or accessories in the region important for the facial recognition during the face image capture process for enrolment and authentication / verification. Changes of garment and / or accessories, e.g. glasses vs. no glasses can influence the biometric performance and PAD mechanism.
- Facial expressions affect facial recognition accuracy, e.g. smiling versus neutral expression [12].
- Facial poses affect facial recognition accuracy, e.g. looking down or away from the camera [12].
- The enrolled facial image can be updated on a regular basis to account for changes over time, e.g. ageing [12] or when significant changes occur, e.g. based on surgeries or injuries.

### **Presentation Condition**

- For authentication via facial recognition, the device which is used for the authentication process is typically optimised to recognize the capture subject within a specified distance range and under certain angles. In addition, external conditions like illumination, humidity or temperature can have an influence on the acquired image. Objects covering the face like glasses, hats and scarfs as well as emotions and physical conditions are to be considered for the functionality of the authentication process.

### **Presentation Attack / Threat**

- Similar to the modality finger, it is possible to use different attack vectors to get access to the device. For possible attack vectors, see Figure 1.
- In devices like smartphones, tablets or notebooks, the built-in camera can be used to capture an image. Without additional sensors or further post processing, e.g. using artificial intelligence, this image includes only 2D data and no further information, e.g. depth or spectral information. This enables the attacker, e.g. to present a printed photo of the enrolled data subject to the capture device. If the enrolled subject is known, photos of the victim target can be found on the internet, or the attacker can acquire an image using a digital camera.
- Additional components / sensors can be integrated to acquire additional information of the claimant, e.g. 3D data of the presented face. In this case, 2D artefacts like photos etc. will typically not work anymore, and more sophisticated PAIs, e.g. 3D masks, are necessary to overcome this kind of countermeasure. Other technologies can acquire spectral information, some materials commonly used for PAI creation can be identified.
- It is possible that a template for a 3D mask can be generated via post processing steps of a 2D image. Based on the template, the mask can be printed by the attacker or ordered via online shops.

### 3 Requirements on Biometric Authentication / Verifications Systems (Normative)

This chapter specifies requirements for biometrics used as an authentication factor. To this end, three different biometric assurance levels (BAL) are deduced from the Assurance Levels (AL) defined in the BSI TR-03107-1 [3].

Note: Mapping of BALs and ALs from BSI TR-03107 and eIDAS shows a gap in the requirements. Therefore, the following table clarifies the mapping between this Technical Guideline and BSI TR-03107-1.

| Resistance against Attack Potential | Biometric Assurance Level (BSI TR-03166) | Assurance Level (BSI TR-03107) | Level of Assurance (LoA) eIDAS |
|-------------------------------------|------------------------------------------|--------------------------------|--------------------------------|
| Basic                               | BAL 1                                    | ---                            | ---                            |
| Enhanced-basic                      | BAL 2                                    | AL normal                      | LoA low                        |
| Moderate                            | BAL 3                                    | AL substantial                 | LoA substantial                |
| High                                | --- <sup>3</sup>                         | AL high                        | LoA high                       |

In addition to biometric specific requirements regarding the biometric performance and resistance against presentation attacks are presented to improve the security of biometric systems.

Chapter 3 of this Technical Guideline is **NORMATIVE**.

#### 3.1 [GEN] General Requirements

The general requirements defined in this section apply to all BALs defined in the following sections.

**GEN-PAD-01:** PAD SHALL be performed for every single biometric presentation.

**GEN-PAD-02:** PAD SHALL be synchronous to the biometric data acquisition and comparison process<sup>4</sup>.

**GEN-PAD-03:** PAD scores and their thresholds SHALL be accessible to the evaluator.

**GEN-PAD-04:** PAD scores SHALL be designed in a manner, which are useful for evaluating biometric systems, e.g., via Hill-Climbing Attacks.

**GEN-PAD-05:** The PAD scores SHALL be inaccessible outside the evaluation process.

Note: The PAD mechanism makes a score accessible to the evaluator, which can be used by the evaluator during the pre-evaluation step to improve the presentation attack instruments. For example, a score which is only 0 or 1 is not useful and does not provide sufficient information to the evaluator.

**GEN-PAD-06:** PAD evaluation SHALL be performed based on the evaluation metrics defined in the BSI Evaluation Guidance of this Technical Guideline.

<sup>3</sup> Requirements for a Level of Assurance “high”, e.g., for applications within European Identity Wallets are covered within the CEN TS 18212 series. Adaptable requirements within the scope of this Technical Guideline will be included in the next version.

<sup>4</sup> If the biometric capture process and the PAD are working subsequently, it might be possible that at first the presentation of an artefact results in a positive biometric comparison and afterwards an attacker presents his own face to circumvent the PAD mechanism, which might be realized via a liveness detection, as a subgroup of possible PAD mechanisms.

**GEN-COM-01:** The biometric comparison score SHALL be accessible to the evaluator during the pre-evaluation process.

**GEN-COM-02:** The biometric comparison threshold SHALL be known by the evaluator for the evaluation process.

**GEN-COM-03:** The biometric comparison score SHALL enable the evaluator to adjust PAIs to exceed the required comparison threshold.

**GEN-COM-04:** The biometric comparison score SHALL be inaccessible outside the evaluation process.

**GEN-DES-01:** For a positive verification / authentication the biometric comparison score SHALL be equal or higher than the biometric threshold and the PAD subsystem SHALL classify the attempt as Bona-Fide.

**GEN-DES-02:** During an authentication process the TOE SHALL only allow a certain limit of biometric authentication attempts, defined by the targeted BAL.

**GEN-DES-03:** If the upper limit for biometric presentation attempts is exceeded, defined by the target BAL or policies, a fall-back to a different verification / authentication method on the at least same or higher BAL or related eIDAS [2] possession- or knowledge-based verification / authentication mean SHALL be performed.

**GEN-COF-01:** The biometric system SHALL be configured with at least one configuration fulfilling the requirements of the general [GEN] and the BAL [BAL-1, BAL-2, BAL-3] requirements specified in the normative Chapter 3 Requirements on Biometric Authentication / Verifications Systems.

**GEN-COF-02:** Multiple configurations fulfilling the requirements for different BALs MAY be implemented to change biometric performance and PAD strength for specific use cases.

**GEN-PER-01:** Manufacturer / integrator SHALL document the required biometric performance evaluation defined by the target BAL.

**GEN-PER-02:** If the TOE allows multiple biometric references for one person, the biometric performance SHALL fulfil the requirements of the target BAL.

**GEN-BTF-01:** The TOE SHALL implement measures to prevent brute force attacks.

**GEN-BTF-02:** The product manufacturer SHALL justify the choice of measures to prevent brute force attacks with respect to the targeted BAL.

**GEN-BTF-03:** The testing laboratory SHALL evaluate the measures and take them into account within the evaluation result.

Note: A potential measure can be a retry counter to limit the attempts for authentication / verification with the biometric system. For additional information see Annex

## 3.2 [BAL-1] Requirements for Biometric Assurance Level 1

The following requirements are defined for the BAL 1 and are REQUIRED for certification purposes.

### 3.2.1 [BAL-1] Biometric Performance and Presentation Attack Detection

#### Biometric Performance

**BAL-1-PER-01:** The biometric system SHALL operate with a biometric performance of 1 false acceptance in 10,000 attempts or better for a single biometric authentication / verification attempt.

#### Presentation Attack Detection

**BAL-1-PAD-01:** Testing of the biometric system SHALL demonstrate resistance against presentation attacks with attack potential “basic” [40] [53] for each pre-defined attack type (i.e., PAI species see Evaluation Guidance).

Note: BSI will provide a list of PAI species, which is available to the testing laboratory to be tested during the PAD evaluation.

### 3.2.2 [BAL-1] Multibiometrics (Conditional)

This section deals with the possibility to use multibiometrics for BAL 1. Therefore, this subchapter is only normative when the TOE uses multibiometric approaches to fulfil the requirements for BAL 1. General information about multi-biometrics can be found in section 2.1.1.2 Multibiometrics. Relevant for this section are multimodality, multiinstance and multipresentation. Some biometric modalities are not suitable to be used in multibiometrics.

**BAL-1-MUL-01:** The multiinstance or the multimodal scheme SHOULD be used to replace a single biometric presentation.

Note: Both instances or modalities have to exceed the required biometric performance and show resistance against the required attack potential.

**BAL-1-MUL-02:** If the multiinstance or multimodal scheme is not available, the multipresentation scheme MAY be used.

**BAL-1-MUL-02a:** If the multipresentation scheme is used, the presented biometric characteristic SHALL provide new biometric features during each presentation attempt.

**BAL-1-MUL-02b:** For the BAL 1, 5 or more presentations covering most of the biometric instance are REQUIRED.

**BAL-1-MUL-03:** The biometric system SHALL operate with a biometric performance of 1 false acceptance in 5,000 attempts or better for each instance or modality for a single biometric authentication / verification attempt.

**BAL-1-MUL-04:** The PAD SHALL perform on the same level as described in the general requirements for the BAL 1.

Note: Multibiometrics can be used e.g., if the biometric performance and or the resistance against a required attack potential is insufficient.

Example: This process can be compared to the enrolment processes for the face unlock function and fingerprint authentication in a smartphone. The face has to be presented from different angles. During the enrolment of a finger, the finger is presented multiple times and slightly shifted each time to capture most



of the finger. The multipresentation scheme enables a PAD for each presentation and contains a higher information content based on a larger number of extracted features.

### 3.2.2.1 [BAL-1] Multimodality (Conditional)

Within the BAL 1, it is possible to combine different biometric modalities. The multimodal approach can be implemented using different types of presentation approaches.

1. **Sequential Presentation**

The different biometric modalities are sequentially presented to the capture device(s).

2. **Simultaneous Presentation**

The different biometric modalities are simultaneously presented to the capture devices.

### 3.2.2.2 [BAL-1] Multiinstance (Conditional)

In the multi-instance scheme, more than one biometric instance is presented to the capture device. Different types of presentation approaches are available:

1. **Sequential Presentation**

The different biometric instances are sequentially presented to the capture device(s).

2. **Simultaneous Presentation**

In case of a sufficiently large sensor area, two or more fingerprints can be acquired at the same time. A segmentation of the captured fingerprints can be necessary depending on the enrolment process.

### 3.2.2.3 [BAL-1] Multipresentation (Conditional)

The multipresentation scheme can be implemented by repeated presentation of the biometric characteristic to the biometric data capture device. The requirements for the multipresentation scheme from 3.2.2 **BAL-1-MUL-02a** and **BAL-1-MUL-02b** SHALL be fulfilled.

Examples: The multipresentation scheme for a finger can be seen comparable to the enrolment process of a single fingerprint, where several regions of the fingertip are presented to the sensor.

For the biometric modality face, the implementation can require to capture pictures from different angles of the face.

## 3.2.3 Enhancing BAL 1 to BAL 2

In section 3.2.2 the possibility to use multibiometrics within BAL 1 is introduced. Multibiometrics from BAL 1 can be used to enhance BAL 1 to BAL 2 under the following requirements.

### General modification to enhance BAL 1

**BAL-1-ENH-01:** Multimodality or Multiinstance approaches based on BAL 1 SHALL be used.

**BAL-1-ENH-02:** The biometric system SHALL NOT reveal the systems decisions after presentation of a single biometric modality.

### Biometric Performance

**BAL-1-ENH-03a:** **BAL-1-PER-01** SHALL be fulfilled for each biometric modality / instance.

or

**BAL-1-ENH-03b:** The biometric system SHALL achieve a biometric performance of 1 false acceptance in 33,333 attempts or better, via the allowed multibiometric approaches for a single biometric authentication / verification attempt.

### **Presentation Attack Detection**

**BAL-1-ENH-04:** The calculated attack potential for the multibiometrics approach SHALL achieve at least an attack potential of “enhanced-basic” [40] [53].

**BAL-1-ENH-05:** The biometric system SHALL be resistant against attacks defined in **BAL-1-ENH-04** and **BAL-2-PAD-02**.

## **3.3 [BAL-2] Requirements for Biometric Assurance Level 2**

The following general requirements are defined for the BAL 2.

### **3.3.1 [BAL-2] Biometric Performance and Presentation Attack Detection**

#### **Biometric Performance**

**BAL-2-PER-01:** The comparison algorithm used with the biometric system SHALL operate with a biometric performance of 1 false acceptance in 33,333 attempts or better for a single biometric authentication / verification attempt.

#### **Presentation Attack Detection**

**BAL-2-PAD-01:** Testing of the biometric system SHALL demonstrate resistance against presentation attacks with attack potential “enhanced-basic” [40] [53].

**BAL-2-PAD-02:** In addition to BAL-1-PAD-02 the evaluator SHALL create new presentation attack instruments with the attack potential “enhanced-basic” [40] [53] independent from the BSI list.

### **3.3.2 [BAL-2] Multibiometrics (Conditional)**

This section deals with the possibility to use multibiometrics for BAL 2. Therefore, this subchapter is only normative when the TOE uses multibiometric approaches to fulfil the requirements for BAL 2. General information about Multibiometrics can be found in section 2.1.1.2 Multibiometrics. Relevant for this section are multimodality, multiinstance and multipresentation. Some biometric modalities are not suitable to be used in multibiometrics.

**BAL-2-MUL-01:** The multiinstance or the multimodal scheme SHOULD be used to replace a single biometric presentation.

**BAL-2-MUL-02:** If the multi-instance or multi-modal scheme is not available, the multi-presentation scheme MAY be used.

**BAL-2-MUL-02a:** If the multi-presentation scheme is used, the presented biometric characteristic SHALL provide new biometric features during each presentation attempt.

**BAL-2-MUL-02b:** If the multi-presentation scheme is used For the BAL 2, 7 or more presentations covering most of the biometric instance are REQUIRED.

**BAL-2-MUL-03:** The biometric system SHALL operate with a biometric performance of 1 false acceptance in 10,000 attempts or better for each instance or modality for a single biometric authentication / verification attempt.

**BAL-2-MUL-04:** The PAD SHALL perform on the same level as described in the general requirements for the BAL 2.

Note: Multibiometrics can be used e.g., if the biometric performance and or the resistance against a required attack potential is insufficient.

### 3.3.2.1 [BAL-2] Multimodality (Conditional)

Within the BAL 2, it is possible to combine different biometric modalities. The multimodal approach can be implemented using different types of presentation approaches.

1. **Sequential Presentation**

The different biometric modalities are sequentially presented to the capture device(s).

2. **Simultaneous Presentation**

The different biometric modalities are simultaneously presented to the capture devices.

**BAL-2-MUL-05:** The biometric system SHALL NOT reveal the systems decisions after presentation of a single biometric modality.

### 3.3.2.2 [BAL-2] Multiinstance (Conditional)

In the multiinstance scheme, more than one biometric instance is presented to the capture device. Different types of presentation approaches are available:

1. **Sequential Presentation**

The different biometric instances are sequentially presented to the capture device(s).

2. **Simultaneous Presentation**

In case of a sufficiently large sensor area, two or more fingerprints can be acquired at the same time. A segmentation of the captured fingerprints can be necessary depending on the enrolment process.

### 3.3.2.3 [BAL-2] Multipresentation (Conditional)

The multipresentation scheme can be implemented by repeated presentation of the biometric characteristic to the biometric data capture device. The requirements for the multipresentation scheme from 3.3.2 MUST be fulfilled.

## 3.3.3 Enhancing BAL 2 to BAL 3

In section 3.3.2 the possibility to use multibiometrics within BAL 2 is introduced. Multibiometrics from BAL 2 can be used to enhance BAL 2 to BAL 3 under the following requirements.

### General modification to enhance BAL 2

**BAL-2-ENH-01:** Multimodality approaches based on BAL 2 SHALL be used.

**BAL-2-ENH-02:** Multipresentation and multiinstance as single approaches SHALL NOT be used.

Note: In case a multimodal approach consists of face biometrics and finger biometrics, but the modality finger includes the multiinstance approach, this would still fulfil **BAL-2-ENH-01**.

### Biometric Performance

**BAL-2-ENH-03a:** Each modality SHALL fulfil the requirements **BAL-2-PER-01**.

or

**BAL-2-ENH-03b:** The biometric system SHALL achieve a biometric performance of 1 false acceptance in 333,333 attempts or better, via the allowed multibiometric approaches for a single biometric authentication / verification attempt.

### Presentation Attack Detection

**BAL-2-ENH-04:** Each biometric modality used SHALL fulfil **BAL-2-PAD-01** and **BAL-2-PAD-02**.

**BAL-2-ENH-05:** The calculated attack potential for the multimodality approach SHALL achieve at least an attack potential of “moderate”.

**BAL-S-ENH-06:** The biometric system SHALL be resistant against attacks defined in **BAL-2-ENH-05**.

Note: The information gained by the system’s biometric evaluation with a single biometric can be used as a basis to enhance the systems biometric system from BAL-2 to BAL-3. Combination of PAIs for BAL “substantial” with a single biometric characteristic can be used.

## 3.4 [BAL-3] Requirements for Biometric Assurance Level 3

The following general requirements are defined for the BAL 3.

### 3.4.1 [BAL-3] Biometric Performance and Presentation Attack Detection

#### Biometric Performance

**BAL-3-PER-01:** The biometric system SHALL achieve a biometric performance of 1 false acceptance in 333,333 attempts or better, via the allowed multibiometric approaches for a single biometric authentication / verification attempt.

#### Presentation Attack Detection

**BAL-3-PAD-01:** Testing of the biometric system SHALL demonstrate resistance against presentation attacks with attack potential “moderate” [40] [53].

**BAL-3-PAD-02:** In addition to BAL-1-PAD-02 the evaluator SHALL create new presentation attack instruments with the attack potential “moderate” [40] [53] independent from the BSI list.

### 3.4.2 [BAL-3] Multibiometrics (Conditional)

This section deals with the possibility to use multi-biometrics for BAL 3. Therefore, this subchapter is only normative when the TOE uses multibiometric approaches to fulfil the requirements for BAL 3. General information about Multibiometrics can be found in section 2.1.1.2 Multibiometrics. Relevant for this section is multi-modality.

**BAL-3-MUL-01:** The multimodal scheme SHALL be used to replace a single biometric presentation.

**BAL-3-MUL-02a:** Each modality SHALL fulfil the requirements BAL-2-PER-01 and BAL-2-PER-02.

or

**BAL-3-MUL-02b:** The biometric system SHALL achieve a biometric performance of 1 false acceptance in 333,333 attempts or better, via the allowed multibiometric approaches for a single biometric authentication / verification attempt.

**BAL-3-MUL-03:** The PAD SHALL perform on the same level as described in the general requirements for the BAL 3

Note: Multibiometrics can be used e.g., if the biometric performance and or the resistance against a given attack potential is insufficient.

### 3.4.3 [BAL-3] Multimodality (Conditional)

Within the BAL 3, it is possible to combine different biometric modalities. The multimodal approach can be implemented using different types of presentation approaches.

1. **Sequential Presentation**

The different biometric modalities are sequentially presented to the capture device(s).

2. **Simultaneous Presentation**

The different biometric modalities are simultaneously presented to the capture devices.

**BAL-3-MUL-04:** The biometric system SHALL NOT reveal the systems decisions after presentation of a single biometric modality.

## 4 Capture of Biometric Characteristics and Enrolment Processes (Informative)

### 4.1 Modality Finger

The biometric authentication subsystem can provide a sufficiently large sensor area in the capture device, which allows additional presentation methods.

Using a sufficiently large fingerprint sensor area, it is possible to capture a rolled fingerprint, which could contain a higher number of biometric features (i.e., minutiae), which could contribute to achieve a lower FAR. In addition to the lower FAR, the creation of an artefact is more challenging due to the necessary 3D information.

In case of a sufficiently large sensor capture device area, two or more fingerprints can be acquired at the same time.

### 4.2 Enrolment Quality Recommendation

To use biometrics with different modalities and instances as an authentication factor, the initial step is the enrolment. The quality of the captured biometric sample is the fundamental basis for the overall success of a biometric verification. Therefore, the enrolment can be performed in a manner obtaining biometric samples providing as many biometric features as possible. An upper bound for the entropy contained in the enrolled biometric template for fingerprints can be calculated for the more realistic model as shown by Ratha et al. [54]. The theoretically achievable entropy of a biometric sample acquired in the enrolment process is not a measure for a security evaluation.

In practice, the number of recognized biometric features in a biometric capture represents only a subset of the reference's biometric features in the most cases. Therefore, the entropy of every biometric capture will not exceed the entropy of the biometric reference. The captured area and the image quality effect the total number of recognizable biometric features. A lower bound for the entropy can be estimated on basis of the specific biometric modality used and the use case.

The given approximation by Ratha et al. [54] can only be applied to the biometric modality finger. A comparable estimation of the information of a frontal face for the modality face is still under debate. Adler et al. [55] estimate the relative entropy, better known as Kullback-Leibler divergence, of a facial image of ~ 55 bit. A similar relative entropy-based estimation by Jassim et al. [56] taking different feature extraction techniques and image qualities into account. Depending on the applied feature extraction and the image quality, the relative entropy according to this publication is in the range of ~ 15 to 334 bits.

Due to different constraints and assumptions it is hard to generalize such findings for a requirement regarding the information content of a facial image. In the future new generalized approaches may be discovered, which can be applied and a requirement can be derived for the quality of biometric data. As stated before the relative entropy of the biometric characteristic is not a measure for the security of the device.

For devices with a long lifecycle, a regular re-enrolment can be an option to preserve the biometric performance.

#### RECOMMENDATION:

- Fingerprint re-enrolment at least every 1 year

- Facial image re-enrolment at least every 6 months

Note: The user can be informed to execute a re-enrolment. An implicit re-enrolment can be done during each successful authentication, this process can be made transparent to the user.

A developer can inform the data subject if any compensation algorithms against aging effects are implemented. Such algorithms can influence the biometric performance.

## 4.3 Re-enrolment and Suspension of a Biometric Characteristic

### Re-enrolment

A re-enrolment of a biometric characteristic can be useful to preserve the biometric performance of the biometric verification system for authentication. Initialization of a re-enrolment can be performed by presenting a former enrolled and still valid biometric characteristic or a valid knowledge- or possession-based authentication factor with an equivalent or better assurance level, e.g., eIDAS or BAL. The enrolled data subject can have the possibility to enrol a new biometric characteristic or the same instance.

Example: The enrolled reference of the data subject can present a sufficient number of biometric characteristics, but due to temporal or permanent changes in the biometric characteristic the performance is not sufficient to verify the user with an existing reference. In addition, it can be possible that the data subject enrolls a biometric characteristic with a sufficient number of features, but in everyday life the data subject uses different parts of the characteristic for authentication by verification. In both cases a re-enrolment of the used characteristic can preserve the biometric performance and the usability of the biometric authentication subsystem.

### Suspension

Suspension is a temporal action, which prohibit the use of the biometric reference and the corresponding biometric instance. The stored biometric reference will not be deleted and can be re-activated by the user by presenting a different biometric characteristic, possession- or knowledge-based authentication factor from the same assurance level or higher.

Example: The owner of the device can share this device with other user and restricts temporarily their authentication to the device and re-activates the authentication at a later date.

# Appendix A (Informative)

## A1. Terms and Definitions

Tab. 3 Table of relevant terms and definitions, based on ISO/IEC 2382-37 and 30107-1–Vocabulary.

| Term                              | Definition                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Artefact</b>                   | Artificial object or representation presenting a copy of biometric characteristics or synthetic biometric patterns                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Attempt</b>                    | Submission of one (or a sequence of) biometric samples to the system                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| <b>Biometric capture device</b>   | Device that collects a signal from a biometric characteristic and converts it to a captured biometric sample                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Biometric capture subject</b>  | Individual who is the subject of a biometric capture process                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Biometric characteristic</b>   | Biological and behavioural characteristic of an individual from which distinguishing, repeatable biometric features can be extracted for the purpose of biometric recognition                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Biometric claim</b>            | claim that a biometric capture subject is or is not the bodily source of a specified or unspecified biometric reference                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| <b>Biometric data subject</b>     | Individual whose individualised biometric data is within the biometric system                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Biometric enrolment</b>        | <p>Act of creating and storing a biometric enrolment data record in accordance with an enrolment policy</p> <p>Note: Enrolment typically involves:</p> <ul style="list-style-type: none"> <li>• sample acquisition,</li> <li>• segmentation and feature extraction,</li> <li>• quality checks, (which may reject the sample/features as being unsuitable for creating a template, and require acquisition of further samples),</li> <li>• template creation (which may require features from multiple samples), possible conversion into a biometric data interchange format and storage,</li> <li>• test verification or identification attempts to ensure that the resulting enrolment is usable</li> <li>• and should the initial enrolment be deemed unsatisfactory, repeated enrolment attempts may be allowed (dependent on the enrolment policy).</li> </ul> |
| <b>Biometric false acceptance</b> | Error of accepting a biometric claim that should have been rejected in accordance with an authoritative statement on the origin of the biometric probe and the biometric reference                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Biometric false rejection</b>  | Error of rejecting a biometric claim that should have been accepted in accordance with an authoritative statement on the origin of the biometric probe and the biometric reference                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| <b>Biometric feature</b>          | Number or label extracted from biometric samples and used for comparison                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |



| Term                                  | Definition                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Biometric probe</b>                | Biometric sample or biometric feature set input to an algorithm for comparison to a biometric reference(s)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>Biometric reference</b>            | One or more stored biometric samples, biometric templates or biometric models attributed to a biometric data subject and used as the object of biometric comparison                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>Biometric sample</b>               | Analog or digital representation of biometric characteristics prior to biometric feature extraction                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| <b>Biometric system</b>               | System for the purpose of the biometric recognition of individuals based on their behavioural and biological characteristics                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Biometric template</b>             | set of stored biometric features comparable directly to a biometric probe                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| <b>Biometric Verification Attempt</b> | <p>Biometric claim and capture attempt(s) that together provide the inputs for comparison(s).</p> <p>Note: Biometric verification will either accept or reject the claim. The verification decision outcome is considered to be erroneous if either a false claim is accepted (false accept) or a true claim is rejected (false reject).</p> <p>Biometric verification typically involves:</p> <ul style="list-style-type: none"> <li>• sample acquisition,</li> <li>• segmentation and feature extraction,</li> <li>• quality checks, (which may reject the sample/features as being unsuitable for comparison, and require acquisition of further samples),</li> <li>• comparison of the sample features against the template for the claimed identity producing a comparison score,</li> <li>• judgement on whether the sample features match the template based on whether the comparison score exceeds a threshold, and</li> <li>• a verification decision based on the match result of one or more attempts as dictated by the decision policy.</li> </ul> |
| <b>Captured biometric sample</b>      | Biometric sample resulting from a biometric capture process.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Comparison</b>                     | Estimation, calculation or measurement of similarity or dissimilarity between biometric probe (s) and biometric reference(s)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| <b>Comparison score</b>               | Numerical value (or set of values) resulting from a biometric comparison                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| <b>Comparison threshold</b>           | Eliminate biometric reference identifier(s) associated with biometric reference(s) and/or identifiers for biometric probe(s) that have failed to attain a level of any type of score                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| <b>Confidence interval</b>            | A lower estimate L and an upper estimate U for a parameter x such that the probability of the true value of x being between L and U is the stated value (e.g. 95 %)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |

| Term                                        | Definition                                                                                                                                                                                                                                                                                                                                                                      |
|---------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>False Accept Rate (FAR)</b>              | proportion of the completed biometric non-mated comparison trials including the presentation phase that result in a false match, based on comparison decision of "match" for a biometric probe and a biometric reference that are from different biometric capture subjects (system level)<br><br>$FAR = FMR * (1 - FTA)$                                                       |
| <b>False Match Rate (FMR)</b>               | Proportion of the completed biometric non-mated comparison trials that result in a false match, based on comparison decision of "match" for a biometric probe and a biometric reference that are from different biometric capture subjects (algorithmic level)                                                                                                                  |
| <b>False Non-Match Rate (FNMR)</b>          | Proportion of the completed biometric mated comparison trials that result in a false non-match based on the comparison decision of "non-match" for a biometric probe and a biometric reference that are from the same biometric capture subject and of the same biometric characteristic (algorithmic level)                                                                    |
| <b>False Reject Rate (FRR)</b>              | Proportion of the completed biometric mated comparison trials including the presentation phase that result in a false non-match, based on the comparison decision of "non-match" for a biometric probe and a biometric reference that are from the same biometric capture subject and of the same biometric characteristic (system level)<br><br>$FRR = FTA + FNMR * (1 - FTA)$ |
| <b>Failure to Acquire Rate (FTA)</b>        | Proportion of a specified set of biometric acquisition processes that were failures to acquire, based on any failure to accept for subsequent comparison the output of a data capture process                                                                                                                                                                                   |
| <b>Genuine attempt, also</b>                | Single good-faith attempt by an enrolled data subject to match their own stored template                                                                                                                                                                                                                                                                                        |
| <b>Acceptable biometric capture attempt</b> | Capture attempt that fulfils the requirements of a biometric capture process                                                                                                                                                                                                                                                                                                    |
| <b>Liveness</b>                             | In our context liveness is a property of the biometric data subject that could be used to determine if the biometric sample stems from a living person                                                                                                                                                                                                                          |
| <b>Liveness detection</b>                   | In our context liveness detection is defined as a subgroup of presentation attack detection mechanisms using the liveness property of a data subject. In other standards this term is used as a synonym for PAD. We clearly decern these term to avoid misunderstandings.                                                                                                       |
| <b>Presentation attack</b>                  | Presentation to the biometric data capture subsystem with the goal of interfering with the operation of the biometric system                                                                                                                                                                                                                                                    |
| <b>Presentation Attack Detection</b>        | automated determination of a presentation attack.                                                                                                                                                                                                                                                                                                                               |
| <b>Presentation attack instrument</b>       | biometric characteristic or subject used in a presentation attack                                                                                                                                                                                                                                                                                                               |
| <b>Verification transaction</b>             | One or more verification attempts resulting in the resolution of a biometric claim.                                                                                                                                                                                                                                                                                             |

## A2. Improving Biometrics Usability

This subsection has an **informative** character and gives advice to hard- and software developers on which general factors can improve the usability of biometrics as an authentication factor. The usability of a biometric authentication system can be linked to the overall system security or at least to the system performance. A frustrated user can circumvent integrated security measures, which can break new attack vectors to the authentication device.

Ideally, if there is more than one biometric modality available that fulfils the requirements of the BAL required, the data subject can choose which modality suits them best. Different biometric modalities can differ in public acceptance and perceived convenience.

The usability of the biometric modality might be increased by practicing the enrolment and authentication process with the biometric modality.

Device affordances (i.e., properties of a device that allow a data subject to perform an action), feedback, and clear instructions are critical to a capture subjects success with the biometric process. For example, clear instructions on the actions required for a successful enrolment and use of the biometric modality are to provide. The instructions can be supported by clear and meaningful pictograms, or, if possible, by explanations in video clips.

To avoid frustration, the system gives clear and meaningful feedback to the capture subject. During the authentication process, this could be done by displaying the remaining number of attempts before authentication will fall back to primary different authentication factor, or the remaining waiting time before the next attempt can be made.

In addition, the system can inform the user if the biometric system has changed its behaviour due to switching to a different BAL (e.g., higher rejection rate due to increased biometric thresholds). This function might be implemented if different services requesting different BALs are accessed using the same biometric system.

Example: The unlocking process of a mobile device implemented via a biometric authentication process requires BAL 1. After a successful first authentication, additional applications become available. Due to their higher risk potential, services like eGovernment or banking applications require BAL 2. During the starting process of the applications, a message informs the user that the change of the BAL required might cause a higher rejection rate due to the adjustment of settings to the BAL 2.

## A3. General Concepts for Improving Biometric Security

This subsection has an informative character and gives advice to hard- and software developers on which general factors can improve usability and security of biometrics as an authentication factor.

Devices with biometric authentication systems can be divided into different categories due to their embedded biometric capture devices. Depending on the intended use cases such systems can have capture subsystems for different biometric modalities like face and finger or support a single biometric modality via multiple technologies. For more information see 2.1.1.2 Multibiometrics.

Ideally, if there is more than one biometric modality available that fulfils the requirements of the BAL required, the data subject can choose which modality suits them best. Different biometric modalities can differ in public acceptance and perceived convenience.

In the following scenarios, it is assumed, that the initial knowledge-based factor during the start / boot process has been entered and the device can be accessed by a successful biometric verification for authentication.

In addition to the responsibilities of the device user, the hardware and software developers inform about potential risks of using biometrics as an authentication factor. Measures as recommended in this section can be implemented by the developer and are easily accessible and adjustable to the user. Therefore, the developer / manufacturer informs the user about the implemented measures to protect sensitive data and application access against unauthorized access.

Therefore, BSI proposes the following possibilities to improve the biometric authentication factor.

1. If possible, an authentication process contains of at least two different and independent authentication factors
  - (Counter-)Example: A physical lock can support biometrics and therefore can be used by a single authentication factor. Improving the security can be achieved by adding a second authentication factor, e.g. a physical token. In addition to act as a possession-based authentication factor, the physical token can contain a portion of the protected reference needed for the biometric authentication process.
  - Note: A physical key has to be usable to open the door at all times.
2. Flexibility regarding the used configuration for biometric performance and presentation attack detection of the biometric authentication system for different use cases.
  - Example: An unlock function to a device can require lower requirements regarding biometric performance and presentation attack detection to improve the overall user experience in terms of accessibility and low occurrence of false rejections of a genuine user.
  - Note: Nevertheless, a user has to consider, that applications after the unlock function can be accessible without an additional authentication.
3. If the device has integrated capture devices for multiple biometric characteristics, they can be used within a multibiometric approach, if higher security is demanded.
  - Example: A device which is capable of using fingerprints and facial recognition as biometric modalities, can use both biometric modalities to strengthen the biometric binding to the user.
  - Note 1: An attacker needs the “biometrics” of all biometric characteristics used in the authentication process in a sufficient quality to achieve a successful comparison. In addition, for both biometric modalities an attacker has to create presentation attack instruments, which generate a false classification of being the genuine user. The total effort to create presentation attack instruments for both and different biometric characteristics is higher in comparison to a single biometric characteristic or multiple biometric characteristics from the same modality (instances).

- Note 2: The influence on the user experience can be limited to a minimum by placing the biometric capture devices at locations fitting the daily use of the device.
4. Enable the use of specific biometric instance for dedicated applications.
    - Example: Some devices can store multiple references of biometric characteristics, e.g. fingerprints. In general, all fingerprints can be interchangeably used for a biometric authentication. Allocating a specific fingerprint, e.g. a different fingerprint than the used during the unlock function, to an application can be beneficial. A single presentation attack instrument will not grant access to all applications on the device. Therefore, the risk that an attacker can gain access to all data and applications can be reduced.
    - Note: With respect to the user experience, the approach using different biometric instances, a user has to remember the biometric instance used for the specific application.
  5. Adaptability of the biometric system by the user to individual security needs
    - Example: Some users want to improve the security of their devices by adapting the predefined parameters, e.g. the maximum time interval or number of attempts until a re-authentication via a knowledge based authentication factor will be requested.
    - Note: With the adaption a user can only “tighten” the requirements with the minimal requirements for the given BAL.
  6. To mitigate brute force attacks on the biometric system different organisational measures can be integrated within the system, for example:
    - Limited retries for the biometric verification / authentication.
    - Increased waiting time between biometric authentication / verification attempts
    - Limitation of the session duration (time) to perform a biometric authentication / verification.
  7. With respect of the different BALs the measures can include:
    - Decreasing number of allowed biometric authentication / verification attempts with increasing BAL level.
    - In case a time delay between biometric authentication / verification is introduced, higher BALs can have an increased delay between the attempts.
    - After a certain time, a different authentication factor (knowledge / possession) can be required by the system with the integrated biometric authentication system. For higher BALs the duration where biometrics as an authentication / verification factor can be used can be decreased.
    - The biometric authentication / verification system can require a different authentication factor (knowledge / possession) after a total number of attempts. Here it does not matter if the authentication attempt was successful or not.

## A4. Abbreviation List

Tab. 4 Abbreviation list of used terms in this technical guideline

| Abbreviation | Regular expression                                                                           |
|--------------|----------------------------------------------------------------------------------------------|
| AL           | Assurance level                                                                              |
| APAR         | Attack Presentation Acquisition Rate                                                         |
| APCER        | Attack Presentation Classification Error Rate                                                |
| APNRR        | Attack Presentation Non-Response Rate                                                        |
| BAL          | Biometric Assurance Level                                                                    |
| BPCER        | Bona Fide Presentation Classification Error Rate                                             |
| BPNRR        | Bona Fide Presentation Non-Response Rate                                                     |
| BSI          | Bundesamt für Sicherheit in der Informationstechnik, Federal Office for Information Security |
| CAPNIR       | Concealer Attack Presentation Non-Identification Rate                                        |
| CAPNMR       | Concealer Attack Presentation Non-match Rate                                                 |
| CC           | Common Criteria                                                                              |
| eIDAS        | electronic IDentification, Authentication and trust Services                                 |
| FAR          | False Acceptance Rate                                                                        |
| FMR          | False Match Rate                                                                             |
| FNMR         | False Non-match Rate                                                                         |
| FRR          | False Rejection Rate                                                                         |
| FIDO         | Fast IDentity Online                                                                         |
| FMR          | False Match Rate                                                                             |
| IAL          | Identity Assurance Level                                                                     |
| IAPAR        | Impostor Attack Presentation Accept Rate                                                     |
| IAPIR        | Impostor Attack Presentation Identification Rate                                             |
| IAPMR        | Impostor Attack Presentation Match Rate                                                      |
| ID           | Identifier                                                                                   |
| IEC          | International Electrotechnical Commission                                                    |
| ISO          | International Organization for Standardization                                               |
| LoA          | Level of Assurance                                                                           |
| NIST         | National Institute of Standards and Technology                                               |
| PA           | Presentation Attack                                                                          |
| PAD          | Presentation Attack Detection                                                                |
| PAI          | Presentation Attack Instrument                                                               |
| PIN          | Personal Identification Number                                                               |
| PP           | Protection Profile                                                                           |
| PSD2         | Payment Services - Directive 2                                                               |
| TR           | Technische Richtlinie, Technical Guideline                                                   |

## 5 Bibliography

- [1] The European Parliament and the Council of the European Union, “Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC,” Brussels, Belgium, 2014.
- [2] The European Parliament and the Council of the European Union, “Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework,” Brussels, Belgium, 2024.
- [3] Bundesamt für Sicherheit in der Informationstechnik, “Technische Richtlinie TR-03107-1 Elektronische Identitäten und Vertrauensdienste im E-Government,” Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2019.
- [4] Bundesamt für Sicherheit in der Informationstechnik, “BSI TR-03121 Biometrie in hoheitlichen Anwendungen,” Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2023.
- [5] Bundesamt für Sicherheit in der Informationstechnik, “BSI TR-03122 Konformitätspezifikation zur Technischen Richtlinie TR-03121 Biometrie in hoheitlichen Anwendungen,” Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2023.
- [6] International Organization for Standardization, “ISO/IEC 30107-1 Information technology — Biometric presentation attack detection — Part 1: Framework,” International Organization for Standardization, Geneva, Switzerland, 2023.
- [7] International Organization for Standardization, “ISO/IEC 30107-3:2023 Information technology — Biometric presentation attack detection — Part 3: Testing and reporting,” International Organization for Standardization, Geneva, Switzerland, 2023.
- [8] S. Bradner, “RFC 2119: Key words for use in RFCs to Indicate Requirement Levels,” Cambridge, USA, 1997.
- [9] International Organization for Standardization, “ISO/IEC 2382-37, Information technology — Vocabulary — Part 37: Biometrics,” International Organization for Standardization, Geneva, Switzerland, 2022.
- [10] National Institute of Standards and Technology, “Digital Identity Guidelines,” Gaithersburg, USA, 2017.
- [11] National Institute of Standards and Technology, “Enrollment and Identity Proofing,” Gaithersburg, USA, 2017.
- [12] National Institute of Standards and Technology, “Authentication and Lifecycle Management,” Gaithersburg, USA, 2017.
- [13] National Institute of Standards and Technology, “Federation and Assertions,” Gaithersburg, USA, 2017.
- [14] Bundesamt für Sicherheit in der Informationstechnik, “Technical Guideline TR-03159 Mobile Identities Part 1: Security Requirements for eIDAS LoA “substantial”,” Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2019.
- [15] Bundesamt für Sicherheit in der Informationstechnik, “Technical Guideline TR-03159 Mobile Identities Part 2: EAC and FIDO based mobile identities,” Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2019.

- 
- [16] International Organization for Standardization, "ISO/IEC 19795 Information technology – Biometric performance testing and reporting – Part 1: Principles and framework," International Organization for Standardization, Geneva, Switzerland, 2022.
- [17] International Organization for Standardization, "Information technology – Biometric performance testing and reporting – Part 9: Testing on mobile devices," International Organization for Standardization, Geneva, Switzerland, 2019.
- [18] International Organization for Standardization, "ISO/IEC 19989-1 Information security – Criteria and methodology for security evaluation of biometric systems – Part 1: Framework," International Organization for Standardization, Geneva, Switzerland, 2020.
- [19] International Organization for Standardization, "ISO/IEC TR 24722:2024 Information technology - Biometrics - Multimodal and other multibiometric fusion," International Organization for Standardization, Geneva, Switzerland, 2024.
- [20] International Organization for Standardization, "ISO/IEC 27001 Information Security Management," International Organization for Standardization, Geneva, Switzerland, 2013.
- [21] International Organization for Standardization, "ISO/IEC 30107-4:2020 Information technology – Biometric presentation attack detection – Part 4: Profile for testing of mobile devices," International Organization for Standardization, Geneva, Switzerland, 2020.
- [22] International Organization for Standardization, "ISO/IEC TR 30125:2016 Information technology Biometrics used with mobile devices," International Organization for Standardization, Geneva, Switzerland, 2016.
- [23] Bundesamt für Sicherheit in der Informationstechnik, "BSI-CC-PP-0063-2010, Fingerprint Spoof Detection Protection Profile," Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2010.
- [24] Bundesamt für Sicherheit in der Informationstechnik, "IT Grundsutz," Bonn, Germany, 2023.
- [25] Bundesamt für Sicherheit in der Informationstechnik, "BSI-Standard 200-1: Information Security Management Systems (ISMS)," Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2018.
- [26] Bundesamt für Sicherheit in der Informationstechnik, "BSI-Standard 200-2: IT-Grundsutz-Methodology," Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2018.
- [27] Bundesamt für Sicherheit in der Informationstechnik, "BSI-Standard 200-3: Risk Analysis based on IT-Grundsutz," Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2018.
- [28] Bundesamt für Sicherheit in der Informationstechnik, "BSI Standard 200-4: Business Continuity Management," Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2023.
- [29] G. C. E. T. M. K. E. N. Stephanie Schuckers, "FIDO Biometrics Requirements," Mountain View, California, United States, 2023.
- [30] THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION, "DIRECTIVE (EU) 2015/2366 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL," *on payment services in the internal market, amending Directives 2002/65/EC, 2009/110/EC and 2013/36/EU and Regulation (EU) No 1093/2010, and repealing Directive 2007/64/EC*, 2015.
- [31] ETSI Technical Committee Cyber Security, "CYBER; Consumer Mobile Device Protection profile," ETSI, Sophia Antipolis Cedex, France, 2021.



- [32] ETSI Technical Committee Cyber Security, "ETSI TS 103 732-2 Consumer Mobile Device; Part 2: Biometric Authentication Protection Profile Module," ETSI, Sophia Antipolis Cedex, France, 2023.
- [33] National Information Assurance Partnership, "Protection Profile for Mobile Device Fundamentals," 2021.
- [34] National Information Assurance Partnership, "Protection Profile for Mobile Device Fundamentals," 2022.
- [35] "Biometrics Security iTC (BIO-iTC)," 21 11 2022. [Online]. Available: <https://biometricitc.github.io/>. [Accessed 13 02 2023].
- [36] Verein eCH, "Qualitätsmodell zur Authentifizierung von Subjekten," Zürich, 2017.
- [37] Common Criteria, "Common Criteria for Information Technology Security Evaluation, Version 3.1 Part 1: Introduction and general model, Revision 5," 2017.
- [38] Common Criteria, "Common Criteria for Information Technology Security Evaluation, Version 3.1, Part 2: Security functional components, Revision 5," 2017.
- [39] Common Criteria, "Common Criteria for Information Technology Security Evaluation, Version 3.1, Part 3: Security assurance components, Revision 5," 2017.
- [40] Common Criteria, "Common Methodology for Information Technology Security Evaluation (CEM), Evaluation Methodology, Version 3.1, Rev. 5," 2017.
- [41] Common Criteria, "Common Criteria for Information Technology Security Evaluation Part 1: Introduction and general model," 2022.
- [42] Common Criteria, "Common Criteria for Information Technology Security Evaluation Part 2: Security functional components," 2022.
- [43] Common Criteria, "Common Criteria for Information Technology Security Evaluation Part 3: Security assurance components," 2022.
- [44] Common Criteria, "Common Criteria for Information Technology Security Evaluation Part 4: Framework for the specification of evaluation methods and activities," 2022.
- [45] Common Criteria, "Common Criteria for Information Technology Security Evaluation Part 5: Pre-defined packages of security requirements," 2022.
- [46] Common Criteria, "Common Methodology for Information Technology Security Evaluation Evaluation methodology," 2022.
- [47] International Organization for Standardization, "ISO/IEC 39794, Information technology – Extensible biometric data interchange formats," International Organization for Standardization, Geneva, Switzerland, 2019.
- [48] International Organization for Standardization, "ISO/IEC FDIS 19795-1 Information technology – Biometric performance testing and reporting – Part 1: Principles and framework," International Organization for Standardization, Geneva, Switzerland, 2021.
- [49] International Organization for Standardization, "ISO/IEC 19794, Information Technology - Biometric Data Interchange Format," International Organization for Standardization, Geneva, Switzerland.

- 
- [50] International Organization for Standardization, "ISO/IEC 24745:2022 Information technology – Security techniques – Biometric information protection," International Organization for Standardization, Geneva, Switzerland, 2022.
- [51] International Organization for Standardization, "ISO/IEC 30136:2018 Information technology - Performance testing of biometric template protecting schemes," International Organization for Standardization, Geneva, Switzerland, 2018.
- [52] J. Z. T. L. G. M. K. C. Mingsi Wang, "A Survey on Physical Adversarial Attacks against Face Recognition Systems," arXiv, 2024.
- [53] Bundesamt für Sicherheit in der Informationstechnik, "Biometric Mechanisms Protection Profile (BMPP)," Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2021.
- [54] J. C. R. B. N.K. Ratha, "Enhancing security and privacy in biometrics-based authentication systems," *IBM Systems Journal*, March 2001.
- [55] A. Y. R. & L. Adler, "Towards a measure of biometric feature information," *Pattern Anal Applic*, pp. 261-270, 2009.
- [56] H. A.-A. A. J. A. a. H. S. Sabah A. Jassim, "Analysis of Relative Entropy, Accuracy, and Quality of Face Biometric," *In the Pattern Recognition for IT Security Workshop, Darmstadt*, September 2010.
- [57] THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION, "REGULATION (EU) No 910/2014 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 23 July 2014," *on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC*, 2014.
- [58] Bundesamt für Sicherheit in der Informationstechnik, "BSI-CC-PP-0062-2010, Fingerprint Spoof Detection Protection Profile," Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, 2010.
- [59] Bundesamt für Sicherheit in der Informationstechnik, "BSI TR-03168 Authentisierungsverfahren und -systeme," Bundesamt für Sicherheit in der Informationstechnik, Bonn, Germany, in preparation 2021.
- [60] International Organization for Standardization, "ISO/IEC 39794-5:2019 Information technology – Extensible biometric data interchange formats – Part 5: Face image data," International Organization for Standardization, Geneva, Switzerland, 2019.
- [61] International Organization for Standardization, "ISO/IEC CD 39794-2 , Information technology – Extensible biometric data interchange formats – Part 2: Finger minutiae data," International Organization for Standardization, Geneva, Switzerland, 2021.
- [62] International Organization for Standardization, "Information technology – Biometric performance testing and reporting – Part 9: Testing on Mobile devicem," International Organization for Standardization, Geneva, Switzerland, 2019.
- [63] CEN/TC 224, "Personal identification - requirements for biometric products".